claude-cluster: security audit

Date: November 3, 2026 · **Sources**: `ai/claude-cluster` (all of `src/`, `include/`, `templates/`, `tests/`), audited at commit `0665950` (version 1.9.4), fixed in version 1.10.0

> **How to read this document**
>
> 1. The summary: the passes, the counts, the verdict.
> 2. The attack surface and how each entry is protected now.
> 3. Every finding fixed, the most severe first.
> 4. What stays open, and the decision it needs.
> 5. The tools that ran, the ones that are missing, the false positives dropped.
>
> Everything is in the commit of version 1.10.0, on `main`. Not covered: the agents themselves, libutils beyond its use here, the Android code beyond its trust model. The window (Qt) was run offscreen only: its code was read and its displays fuzzed, its paste was not driven by a real clipboard.

Contents

1. Summary
2. Attack surface
3. Fixed
4. Open
5. Tools and false positives

1. Summary

Point	Conclusion
Passes	**7**: the seventh pass, a confirmation run of the whole suite and the sanitizers, found nothing new
Findings	**184** fixed: **6** critical, **37** high, **79** medium, **62** low
Open	**6**, a decision for the user or nothing to do in this code (part 4)
False positives	**13** dropped, with their reason (part 5)
The worst	a paired device could get a shell on the computer with `[web] shell = false`, three ways
What ended the core	JSON nested very deep, an exception out of any thread, a use after free at each quit, two pages opening the terminal
What lost data	two saves at once corrupted `state.json`; a keep-warm take-back killed the background and could erase a real prompt
Tests	**141 test files, 0 failed on the optimized build (the last run); each fix has a regression test**
Sanitizers	ThreadSanitizer on 38 tests: only 3 known benign reports (`std::ctype<char>::narrow` during regex compile, `free` in `tzset_internal` under `mktime`, an unsymbolized read of the same kind). AddressSanitizer + UndefinedBehaviorSanitizer on 141 tests: no memory error; the failures are time bounds of a slow build (they pass optimized and alone). Fuzzing: 472295 runs in 171 s, no crash
Commit audited	`0665950`, version 1.9.4; fixed in version 1.10.0

> **Key takeaway**: the design holds (a pairing code and an approval, one core per user, a private socket); the holes were at the edges: a gate written twice and differently, a shape of input nobody expected, threads outliving what they use.

Findings per pass:

Pass	What it was	Found
1	first full reading, sanitizers on the test suite	47

Pass	What it was	Found
2	the rest of the code, fuzzing of the web access and displays, the paste	19
3	my own fixes read again	7
4	an independent reading of each subsystem, every finding reproduced and checked again (99 confirmed, 93 entries)	93
5	the fixes of pass 4 read again, ThreadSanitizer races, callbacks, gdbus, git panels	15
6	the fixes read again, the confirmation run caught a stale settings read; three findings, all from fixes of this audit, never released	3
7	confirmation: the whole suite, ThreadSanitizer, fuzzing and AddressSanitizer, nothing new	0

2. Attack surface

Entry	Who reaches it	How it is protected now
Web port (HTTP / TLS)	the LAN, or a tailnet / a router port when asked	this network only, `Host` and `Origin` checked, 16 KB of headers, a body over 4 KB read for a device really connected only, 64 connections and a limit per address, a pairing code (5 wrong codes block an address) and your approval, cookies bound to the device and its address, a CSP with a nonce
WebSocket of the terminal page	a paired device	origin checked, frames of 1 MB at most, ping / close handled, the device checked again every second
`/api/cmd`	a paired device	a list of commands; `raw` and `origin` set by the server; every prompt through `prompt_refused`; a task or schedule with a command refused with the shell off; `[web] settings` sections only; hidden files never shown
`/api/attach`, `/api/file`	a paired device	size cap, type sniffed, a program refused, name made safe, `0600`, `magick` bounded, a session reads its folder only, streamed, `CSP sandbox`
Control socket	this user	folder and socket checked to be yours, `0600`; `origin` tells the global session, a sub-session, a device apart; JSON nested 512 levels at most
MCP tools	every agent	the same `Control::handle`: protected settings refused, hidden paths refused, `subGate_` for the sub-sessions
Output of an agent	any model, what it read	each line parsed in a guard, a line without end bounded, a display checked for its shape, its numbers clamped when drawn
Files of other tools (`~/.claude`, codex, qwen)	what they wrote	read with a limit of depth, a file of an unexpected shape skipped
Terminal input	the user, what they paste	a paste is never keys; a pasted block never runs; 64 MB at most
Update	a binary installed	tried first as a core of its own and asked its status, the held prompts kept on disk, nothing stopped if it fails

3. Fixed

3.1 Critical (6)

`:set web.shell=true` typed in a prompt opens the shell of the computer to a device of the page

Where	`src/cluster/Prompt.cpp:235` · Auth & access · Critical · pass 1
What it allowed	A paired device with `[web] shell = false` turned the setting on through the `:set` mode of a prompt, then ran any `! command` as the user.
Evidence	Read: `/api/cmd send` only looked for `!`; `:set` ran `settings_set` with no `web_may` check. Reproduced in `tests/web_gate.py`.
Fix	One gate, `prompt_refused`, called by `Control::handle` on `send` and `slash`, by the terminal of the page too. It reads the text the way it will run.
Regression test	`tests/web_gate.py`

A schedule or a task running a command walked around `[web] shell = false`

Where	`src/cluster/Control.cpp:133` · Auth & access · Critical · pass 1
What it allowed	A paired device with the shell off created `schedule_add {action: command}`, `if.command` or `on_event {type: command}` and got `/bin/sh -c` on the computer.
Evidence	Read and reproduced in `tests/web_gate.py` (the marker file appeared on the old code).
Fix	`carries_command_` refuses a local command anywhere in the request of `task_add`, `schedule_add`, `schedule_edit`, `task_act set`.
Regression test	`tests/web_gate.py`

A hidden tag character before `!` passed the shell gate

Where	`src/cluster/Prompt.cpp:240` · Injection · Critical · pass 1
What it allowed	`U+E00xx` first: the gate read `trim(text)` and saw no `!`, `run_slash` dropped the tag and ran the command.
Evidence	Reproduced in `tests/web_gate.py` (`... its hidden characters first`).
Fix	The gate reads the prompt untagged, as `run_slash` does.
Regression test	`tests/web_gate.py`

Terminal page: Ctrl+E opens a real editor on the device's pty, so :! gives a shell with [web] shell off

Where	`src/cluster/ui/Tty.cpp:1652` · Auth & access · Critical · pass 4
What it allowed	Any paired device on the terminal page. It is on by default when web is on: Config.hpp:111 ttyPort = 2222, `shell` off. Ctrl+E, then :!anything, or :w ~/.bashrc.
Evidence	Path: POST /api/tty/write or a WebSocket binary frame -> pty of `claude-cluster --tty` (CLAUDE_CLUSTER_WEB_TTY=1) -> key `edit` (Ctrl+E) -> Tty.cpp:3510-3511 externalEdit_() (1645) -> editorCommand_() picks nvim / vim / vi -> process.spawn inside WithRestoredIO with no _webTty check.
Fix	When *webTty && !config.web.shell, refuse in externalEdit*() and in settingsAction_() for the edit_* keys, with the same status text as the shell gate. Every foreground program of the terminal page then goes through that one gate.
Regression test	`tests/web_tty_gates.py`

[web] shell = false: a `command` that is not a string passes carries_command_ and runs in /bin/sh

Where	`src/cluster/Control.cpp:135` · Auth & access · Critical · pass 4
What it allowed	Any paired device with [web] shell off: schedule_add, schedule_edit, task_add are in the /api/cmd list
Evidence	carries_command_ refuses `command` only when value.is_string() (Control.cpp:139) and compares action / type to the exact word "command" (:140). opt::text (include/cluster/Options.hpp:34) dumps a non-string to its JSON text, and that text is the command: if.command Manager-Schedules.cpp:146 -> command_check, action command Manager-Schedules.cpp:404, on_event Manager-Tasks.cpp:128; action and type are lower-cased there...
Fix	Refuse a non-null `command` of any type and compare action / type lower-cased in carries_command_; refuse a non-string command in applySchedule_ / addTaskJson (never opt::text on a command)
Regression test	`tests/command_shapes.py`

A NUL byte in a path fools hidden_path: a device with the shell off overwrites ~/.bashrc and gets a shell; every hidden-file gate falls

Where	`src/cluster/Tools.cpp:928` · Auth & access · Critical · pass 4
What it allowed	A paired device with [web] shell = false (POST /api/cmd send with the /export text), or the global session through its export / context / display tools. For the shell, the device puts its command line in a prompt first, then exports over the rc file.
Evidence	JSON \u0000 stays in the std::string. hidden_path (Tools.cpp:928) runs lexically_normal on the whole string, so `/home/u/.bashrc\0/../../x.md` normalizes to `/x.md` (enough `..` cancels every folder): no dot component, returns false. The kernel only sees the part before the NUL.
Fix	At the top of hidden_path: `if (path.find('\0') != std::string::npos) return true;`. A path with a NUL is never a real path.
Regression test	`tests/hidden_paths.py`

3.2 High (37)

JSON nested very deep ended the core (stack overflow, SIGSEGV)

Where	`src/cluster/Tools.cpp:1226` · Crash / DoS · High · pass 2
What it allowed	A device of the page (bodies up to 1 MB), any agent through its MCP tools or its output, or a file: a line of 200 000 `[` killed the core and every session. nlohmann parses any depth, its copies and dumps recurse.
Evidence	`{"cmd":"display",...,"data":[[[[...` on 1.9.4: exit `-11` (`json_deep.py`).
Fix	`cluster::json_parse` limits the depth to 512 levels, a parse error like any malformed text. Every `Json::parse` of the core goes through it.
Regression test	`tests/json_depth.py`

The numbers of a chart took all the memory of the computer

Where	`src/cluster/ui/Tty.cpp:5601` · Crash / DoS · High · pass 2
What it allowed	An agent (a prompt injection in what it reads) displays a pie chart `[1e300, -1e300, 1]` : the terminal fills a string in a loop until the machine swaps or the OOM killer acts, and again at every start since the display stays in the log.
Evidence	1.9.4 under a 1 GB limit: killed by SIGABRT after 2.9 s (`numbers_old.py`).
Fix	`cluster::between` clamps every ratio to 0..1 (sparklines, bars, timeline, heatmap, terminal and window).
Regression test	`tests/display_shapes.py` , `tests/gui_shapes.py`

A display of an unexpected shape killed the terminal, at each start

Where	`src/cluster/ui/Tty.cpp:9116` · Crash / DoS · High · pass 1
What it allowed	`{"type":"markdown","text":1}` from an agent: the terminal exits at each draw, and at each new terminal since it stays in the log.
Evidence	Fuzz in `tests/display_shapes.py` found it.
Fix	Field kinds checked in `display_prepare` ; every draw guarded; a frame that fails is told in its place; the window catches what its handlers throw (`GuardedApplication`).
Regression test	`tests/display_shapes.py` , `tests/gui_shapes.py`

An exception out of any thread ended the core

Where	`include/cluster/Tools.hpp:182` · Crash / DoS · High · pass 1
What it allowed	About 60 threads: a reader of an agent, the tick, a request. An exception (an event of an unexpected shape, a file gone, EACCES) reached `std::terminate` : every session gone.
Evidence	Read; `Session::line_` only caught JSON errors, the tick only `IException` .
Fix	`cluster::guarded` wraps every thread; the sub-ticks, the listeners and the agent reader are guarded one by one.
Regression test	`tests/display_shapes.py` , `tests/web_fuzz.py`

Use after free at every quit and update

Where	`src/cluster/Core.cpp:135` · Memory · High · pass 1
What it allowed	Long polls of interfaces and of the page (up to 110 s) outlived `~Web` and `~Manager` . Crash at the quit, the watcher then starting a core nobody wants; the logged `crashed (signal 11)` .
Evidence	Read (`Control::client_` , `Web::client_`); `core.log` of the user; reproduced under ASan by `tests/web_tty_race.py` .
Fix	`App` is never destroyed: stopped in order, `_Exit` at the end of `main` .
Regression test	`tests/web_tty_race.py`

Two saves at once corrupted `state.json` : every session lost at the next start

Where	`src/cluster/Tools.cpp:943` · Concurrency · High · pass 1
What it allowed	`save()` from every thread wrote to one `.tmp` then renamed it: a mixed file, unreadable at the next start.

Evidence	Reproduced by `tests/state_save.py`.
Fix	`save` serialized; `replace_file_` writes a unique temporary file (`O_EXCL`).
Regression test	`tests/state_save.py`

Two pages opening the terminal at once ended the core

Where	`src/cluster/WebTty.cpp:220` · Concurrency · High · pass 1
What it allowed	A second session dropped with its reader joinable: `std::terminate`, from any device with two tabs.
Evidence	Reproduced by `tests/web_tty_race.py`.
Fix	`try_emplace` : the first kept, the other ended properly.
Regression test	`tests/web_tty_race.py`

`session_edit keep=N` read through `end()` (SIGSEGV of the core)

Where	`src/cluster/Manager-External.cpp:116` · Memory · High · pass 1
What it allowed	The const `operator[]` of nlohmann on a missing key is undefined behaviour under `NDEBUG` : the global session crashed the core on a transcript with non-message lines.
Evidence	Read, reproduced with a crafted transcript.
Fix	Guard at the site; `JSON_ASSERT` now throws in the whole program (`include/cluster/JsonAssert.hpp`): this class of bug became an exception.
Regression test	`tests/display_shapes.py`

A keep-warm wake-up taking back its prompt killed the background of the session

Where	`src/cluster/Session.cpp:2065` · Logic · High · pass 1
What it allowed	The take-back stops the agent: shells and agents running in the background died at each wake-up (a regression of 1.9.2).
Evidence	Read; `tests/keep_warm_all_background.py` (the agent pid unchanged, now).
Fix	`wakeLast_` : never a take-back while the background runs; the wake-up goes after it.
Regression test	`tests/keep_warm_all_background.py`

A keep-warm take-back could erase a real prompt

Where	`src/cluster/Session.cpp:1973` · Concurrency · High · pass 1
What it allowed	`rewind_point_` runs outside the lock (seconds): a prompt given meanwhile was stopped and its entry cut.
Evidence	Read the exact path; `tests/keep_warm.py`.
Fix	Checked again under the lock; `_takingBack` keeps what is sent meanwhile, sent after in its order.
Regression test	`tests/keep_warm.py`

`/api/attach` ran the code of `/api/listen` : uploads sent to the speech engine

Where	`src/cluster/Web.cpp:1954` · Logic · High · pass 1
What it allowed	Since 73245fc the voice branch sat under `/api/attach` : an attached file went to the speech model of the settings (possibly a cloud provider), two answers on a connection, the microphone of the page dead.
Evidence	Read; `tests/web_listen_attach.py`.
Fix	The two routes separated.
Regression test	`tests/web_listen_attach.py`

The letters of a paste answered the popups

Where	`src/cluster/ui/Tty.cpp:8143` · Auth & access · High · pass 2

What it allowed	With a popup of keys open, a text pasted was replayed as keys: `a` allowed a device asking to connect, `t` trusted it, `b` banned, `n` started without the sessions, `q` quit.
Evidence	`paste_end.py`: a paste in the popup of the map of this computer ended the terminal.
Fix	A paste goes to a text field only; a popup of keys refuses it with a note.
Regression test	`tests/paste_import.py`

A pasted block starting with `!` ran as a command on Enter

Where	`src/cluster/Actions.cpp:1425` · Injection · High · pass 2
What it allowed	Paste-jacking: a text copied from a page with `!curl ... | sh` as its first line shows only `[Pasted text #1 +40 lines]`; Enter ran it. Same for `:set`, `/export`.
Evidence	Read: `expand` then `slash_untag` drops the marks.
Fix	`pasted_first`: what starts with a paste mark is a prompt, never run. `!` typed first still runs it.
Regression test	`tests/paste_import.py`, `tests/web_gate.py`

The terminal of the page pasted escapes as they are

Where	`templates/tty.html:448` · Injection · High · pass 2
What it allowed	A copied text holding `ESC[201~` ended the paste early: the rest became keys, its line breaks sent prompts or ran `! commands`.
Evidence	Read `tty.html`: the text was only wrapped in brackets.
Fix	ESC and C1 CSI removed, as a real terminal does.
Regression test	`tests/page_import.py`

The protected settings had the wrong names: the global session could open its own gates

Where	`src/cluster/Settings.cpp:1272` · Auth & access · High · pass 1
What it allowed	`global.fork` … instead of `sessions.global_fork`: the global session could turn on its own rights (F2 of the first audit, still open). Attachments, `agent.sub_*`, `global_pin`, `taxonomy_edit` were missing too.
Evidence	Compared with the real rows; `tests/pin.sh`.
Fix	The list fixed.
Regression test	`tests/pin.sh`

`/export`, `:w`, `/update`, `:r` from the page and the global session

Where	`src/cluster/Prompt.cpp:267` · Files & system · High · pass 1
What it allowed	`/export ~/.bashrc` overwrote a file anywhere, `:r` read any file of the computer into the answer, `/update` was not reserved to the user. Variants `: w`, `:export`, `:update` found in pass 2.
Evidence	`tests/web_gate.py`.
Fix	The same gate: `.md` / `.txt` out of the hidden folders; `:r` with the shell only; reads capped.
Regression test	`tests/web_gate.py`

The Open button of a file display renders agent HTML in the page's origin: one click in it runs any /api/cmd

Where	`templates/web.html:1037` · Injection · High · pass 4
What it allowed	Any agent, for example a prompt injection in what it reads, writes report.html and displays it; the user clicks Open, then a button in it. The command then runs as the device: send a prompt to the global session (bypassPermissions by default), `apply`, `allow`, delete.
Evidence	Path: agent session_display {type:file, path:report.html} -> Display.cpp:339 mime text/html -> Web.cpp:1875-1877 serves it with Content-Disposition: attachment + CSP sandbox -> web.html:2264-2268 fetch().blob() then URL.createObjectURL + a.click(). The blob keeps type text/html and has the page's origin, and the blob drops those two response headers.

Fix	Open only image / PDF blobs as they are; give text/html, SVG and XML a blob of type text/plain, or download them. Also make POST /api/cmd (and the other JSON routes) require Content-Type: application/json, which a plain form cannot send.
Regression test	`tests/web_open_file.py`

The global session can attach ~/.ssh/id_rsa: the hidden check is skipped when the file is in the session's folder

Where	`src/cluster/Attachments.cpp:268` · Secrets · High · pass 4
What it allowed	A manipulated global session: origin mcp spawn with cwd=~ (the test did this), then session_send with attachments ["~/.ssh/id_rsa"]. Any hidden file under a session's folder works the same way.
Evidence	Path: origin mcp `send` with attachments -> Control.cpp:777 attach_link(..., AttachScope::Global, target->spec.cwd) -> Attachments.cpp:270-275: `inProject` true skips the hidden-folder loop and the refuse. Reproduced, isolated, with `{cmd:send, origin:mcp, attachments:["~/.ssh/id_rsa"]}`. To a session in ~/work: refused.
Fix	In the Global scope, refuse when cluster::hidden_path(target.string()) is true, whatever inProject says.
Regression test	`tests/hidden_paths.py`

Global session: config_write/read of voice_words & vocabulary = arbitrary file write and read anywhere

Where	`src/cluster/Settings.cpp:1278` · Files · High · pass 4
What it allowed	The global session's own MCP tools (settings_set + config_write/config_read), which the trust model treats as manipulable by text it reads; also a web device if [web] settings includes "voice".
Evidence	config_files_ builds the voice_words / vocabulary entries from `voice_words_path(c.voice.words)` / `vocabulary_path(c.voice.vocabulary)` (Control.cpp:332-335) with globalMay defaulting true. `voice.words` and `voice.vocabulary` are NOT in setting_protected (Settings.cpp:1264-1266), so the global session (origin mcp) may settings_set them to any path, then config_write/config_read (Control.cpp:952-982, 945-951) writes...
Fix	Protect voice.words / voice.vocabulary (add to setting_protected) and/or restrict them to a safe location; apply hidden_path + extension checks in config_write/config_read for the global/web origins, and resolve the ConfigFile path against a fixed directory rather than a config-controlled arbitrary...
Regression test	`tests/hidden_paths.py`

pin with an inline display block bypasses the hidden-file display gate (reads any file)

Where	`src/cluster/Control.cpp:1507` · Secrets · High · pass 4
What it allowed	A paired web device, or the global session, issuing pin/session_pin with an inline display block whose path is a hidden/secret file.
Evidence	The `display` and `display_update` commands run hidden_in_ over the block for from_global/from_web (Control.cpp:1209-1211, 1217-1219). The `pin` command (1410) calls Manager::pin, which for an inline `display` object calls Manager::display -> display_prepare (Manager-External.cpp:467-470), reading the file (e.g. type audio/image/file path) and base64-encoding it into the display — with NO hidden_in_ check.
Fix	Run hidden_in_(request["display"]) for from_global/from_web in the pin branch (Control.cpp:1405-1412) exactly as the display / display_update branches do, before Manager::pin.
Regression test	`tests/hidden_paths.py`

The restore answer starts the global session twice: its conversation replaced by a new one, or the whole core frozen

Where	`src/cluster/Manager.cpp:2327` · Data loss · High · pass 4
What it allowed	The user answers the previous-run question: a linger core with restore='ask', reached with [ui] start_menu=false or an independent instance (no start menu with CLAUDE_CLUSTER_SOCKET set). The longer restorePrevious takes (many sessions, big logs), the more likely the conversation loss.
Evidence	Path: Control restore_answer -> Manager::answerRestore (Manager.cpp:2100) sets *restoreAsk=false BEFORE restorePrevious() and startGlobal(). Meanwhile the tick runs ensureGlobal* (Manager.cpp:920-934): _restoreAsk false, no global yet -> a second startGlobal in a thread. Same window while startGlobal waits for `claude agents --json` (Manager.cpp:884, up to 15 s).
Fix	answerRestore: `if (!_restoreAsk.exchange(false)) return` but only clear the flag after startGlobal (or hold *globalRetrying during it); ensureGlobal* must not fire while a start runs.
Regression test	`tests/restore_answer.py`

Config::load rewrites the settings under the readers of every thread: SIGSEGV of the core on a settings change

Where	`src/cluster/Config.cpp:536` · Concurrency · High · pass 4
What it allowed	Any change of config.toml (the settings page, /keepwarm turning the mode on, the global session, a device allowed by [web] settings, an edit by hand) while another thread reads the same container (a page polling, an interface).
Evidence	Config has no lock. Config::reload -> load -> defaults_ (Config.cpp:68-69: `styles = builtin_styles_(); keys = {...}`), then strings, vectors and maps reassigned, profiles/providers cleared (:495, :512). Writers: the tick (Manager.cpp:1508) and any request thread (Control.cpp:1198, :1312, Manager.cpp:553, :656, :1270, Web.cpp:762, Services.cpp:284), two can run at once.
Fix	Serialize writers with a mutex in reload. For readers, either parse into a new Config and publish it through an atomic shared_ptr, or, as the minimum for this release, build maps and vectors aside and swap only when changed, and never reassign styles/keys when they did not change; do not hand out re...
Regression test	`tests/config_reload_race.py`

A keep-warm take-back erases a real turn the agent started by itself after a wake-up

Where	`src/cluster/Session.cpp:2067` · Data loss · High · pass 4
What it allowed	keep warm on and a Monitor / background turn firing after a wake-up (the case README and Event::spontaneous describe). The next wake-up, about 4 min later, deletes its result from the transcript and from the conversation of the agent, before the user read it.
Evidence	wakeLast_ (Session.cpp:1881-1884) only checks that the last EntryKind::User entry starts with KEEP_WARM_MARK. A turn started by the agent (a Monitor, a background task told by claude itself) adds no User entry: no dispatch_, and a replay starting with '<' is skipped at :770.
Fix	wakeLast_ must also require that nothing but the wake-up's own answer followed: for example _data.warming still true (see the warming finding), or no more than one Assistant entry and no Tool entry after the last User entry. When unsure, no take-back: the wake-up goes after.
Regression test	`tests/keep_warm_turns.py`

rewind_point_ does not check it found the wake-up: a take-back can cut the last real prompt out of the conversation

Where	`src/cluster/Session.cpp:214` · Data loss · High · pass 4
What it allowed	A quit, an update (keepWarm_ still runs in the 2.5 s after the update's last check, Manager-Upgrade.cpp:523) or a crash in the seconds between writing a wake-up and claude reading it (agent loading), then a start within the cache time. Per quit, about 1% per session kept warm.
Evidence	takeBackWake trusts the last User entry of OUR log, then rewind_point_(claudeId, leaf, 1) walks from spec.leaf to the first prompt on the chain and returns its parent (Session.cpp:222-229), whatever that prompt is. dispatch_ writes the User entry (and flushes it) before claude has read the message. If the agent never read it, leaf stays on the real answer and the prompt found is the REAL one.
Fix	For byUser=false make rewind_point_ return nullopt unless the prompt it finds is the wake-up (keep a `wake` flag in Message, from content starting with KEEP_WARM_MARK): no cut, the next wake-up goes after.
Regression test	`tests/keep_warm_unread.py`

data.warming is never cleared when a turn starts without dispatch: the next real turns are silent, no reply and no task end

Where	`src/cluster/Session.cpp:812` · Logic · High · pass 4
What it allowed	Keep warm on and, after a wake-up: a Monitor / background turn, or a prompt typed on claude.ai through Remote Control.
Evidence	warming is only written in dispatch_ (:1543) and giveQueued (:1580). A turn started by the agent, or a prompt from claude.ai (replay branch :762-777), keeps the true left by the last wake-up. emit_ carries it (:1439) and Manager::event_ breaks at once on event.warm (Manager.cpp:1084-1089), before limitsWarn, turnCounted_, *restartAfterTurn, replyEnd*, notify, onGlobalAnswer and taskDone_.
Fix	Where a turn starts with state Idle without dispatch_ (:749 and the replay at :772): `_data.warming = false`. Keep the value otherwise, the page reads it after the end of a wake-up.
Regression test	`tests/keep_warm_turns.py`

Typing or pasting `:` in the prompt freezes the terminal for ever and crashes the window

Where	`src/cluster/Editor.cpp:616` · Crash & DoS · High · pass 4
What it allowed	The user, a device of the terminal page, or a copied text starting with `:` or `:\n`. Any session, no agent needed; the unsent prompt is lost.

Evidence	Editor::refresh_: text starting with ':' , cursor past the first word, nothing but spaces / line breaks between: head = trim(before.substr(1)) is empty, then `cluster::split(head, ' ')[0]` on an empty vector, a std::string copied from address 0.
Fix	const std::vector parts = cluster::split(head, ' '); const std::string command = parts.empty() ? std::string() : parts[0]; (the kind stays None).
Regression test	`tests/prompt_edit_shapes.py`

The terminal page writes protected settings past [web] settings (simple mode window, questions of the map)

Where	`src/cluster/ui/Tty.cpp:3425` · Auth & access · High · pass 4
What it allowed	A paired device on the terminal page; the simple window needs the computer in the simple mode, the map questions need nothing.
Evidence	setSetting_ has the web_may gate, these two do not and write config.toml directly from the terminal process, so the gate of Control never runs. simpleSave_ line 3255: reproduced with [ui] mode = simple, CLAUDE_CLUSTER_WEB_TTY=1, no [web] settings: F9, Tab, Tab, Down, Down, Left, Enter, Enter -> config.toml holds permission_mode = "bypassPermissions".
Fix	simpleWinKey_ / simpleSave_: read only when *webTty && !web_may(section), as setSetting*; run_: refuse machine_sync when *webTty (the startup question already is); profileNext*: no settings_set when _webTty.
Regression test	`tests/web_tty_gates.py`

A small display or answer costs rows x columns of memory and time at every frame of the terminal

Where	`src/cluster/ui/Tty.cpp:443` · Crash & DoS · High · pass 4
What it allowed	Any agent: session_display, or the text of an answer for the markdown table and the brackets (a prompt injection in what it reads). No user action but showing the session.
Evidence	Only the numbers were clamped by the chart fix, not the dimensions. transcript_ rebuilds every line at each frame. Measured under RLIMIT_AS 1.6 GB: chart 222 KB (12000 values + 12000 empty series, lines 5396-5405 make count x series Rows of 200+ bytes): `this screen could not be drawn: std::bad_alloc` in 8 s, about 40 GB without the limit; table 263 KB (one row of 30000 cells + 30000 empty rows, every row padded to `...
Fix	Draw a bounded part: at most N rows / M columns / count x series lines in table, kanban, chart, with a `… n more` line; a running width in actions; plain_md_: stop looking for `]` after the first miss.
Regression test	`tests/display_bounds.py`

A heatmap or a timeline of a few KB makes the window allocate gigabytes

Where	`src/cluster/ui/Gui.cpp:6007` · Crash & DoS · High · pass 4
What it allowed	Any agent: session_display heatmap / timeline, a window showing that session.
Evidence	heatmap_: QImage(50 + columns * size + 10, 24 + rows * size + 10) with size at least 8, then fill() touches all of it; `columns` is the widest row, rows may be empty. Measured offscreen: {"type":"heatmap","rows":[[null x 1800], [] x 1800]}, 17 KB: peak RSS of the window 71 MB -> 869 MB. Quadratic: 10000 x 10000 (80 KB of JSON) asks 25 GB.
Fix	Clamp what is drawn: columns and rows to a size giving at most about 2000 x 2000 pixels (a cell of 1-2 pixels, or a `… cut` label), tasks to a few hundred; refuse them in display_prepare past that.
Regression test	`tests/gui_bounds.py`

Sub-session gates compare exact words at the top level only: local commands, prompts into other sessions and into the global session

Where	`src/cluster/Control.cpp:539` · Auth & access · High · pass 4
What it allowed	An agent of a sub-session (a prompt injection in what it reads) through its MCP tools task_add, schedule_add, schedule_edit
Evidence	subGate_ tests arg_(on,"type") == "command" (:497) and action == "command" (:507) on the top-level request; the core lower-cases them (Manager-Tasks.cpp:122, Manager-Schedules.cpp:100) and copies `options` whole (Manager-Schedules.cpp:155), which execute_ gives to addTaskJson. schedule_edit never forces the session (Manager-Schedules.cpp:108: empty = global).
Fix	Gate on what will run: lower-case action / type, the carries_command_ check (any type, nested in options) for from_sub too, target = owner for action task (options included), session = owner on schedule_edit as on schedule_add
Regression test	`tests/command_shapes.py`

max_cost "inf" (or a cost summing to inf) writes null in state.json: the core never starts again

Where	`include/cluster/Options.hpp:65` · Crash & DoS · High · pass 4
What it allowed	A paired device or a sub-session (task_add, task_act set); an agent's result lines
Evidence	opt::decimal: std::stod("inf") -> inf, std::max(0.0, inf) (Manager-Tasks.cpp:113, :233). nlohmann dumps a non-finite number as null. Manager::load: t.get() (Manager.cpp:1367) throws type_error 302 with no guard per item, up to main.
Fix	Refuse non-finite numbers in opt::decimal and when summing a cost; in load(), a try/catch per schedule, spec and task: one bad item never stops the core
Regression test	`tests/task_max_cost.py`, `tests/state_bad_item.py`

A task with its own session is sent to another project's session after a restart

Where	`src/cluster/Manager-Tasks.cpp:469` · Logic · High · pass 4
What it allowed	A quit with stop, a Restart or a crash while a task with spawn (task_add, schedule action spawn) runs
Evidence	load() turns running into queued (Manager.cpp:1368) with spawned = true and target empty. schedule_ does not spawn again since its session exists (:443), then :461 `task.target.empty()` matches the first idle session of _order. The retry paths set target = session (:320, :645), load does not.
Fix	In load(): if (task.spawned) task.target = task.session
Regression test	`tests/task_restart.py`

An exception in the update thread leaves _holding on for ever: update stuck, every prompt, task and schedule frozen

Where	`src/cluster/Manager-Upgrade.cpp:544` · Crash & DoS · High · pass 4
What it allowed	Update (an interface, u / U of the supervisor) while the global session is not there yet: question pending, global failing to start
Evidence	holdQueues_ calls unqueue for each session of list(true), which holds a placeholder "g" when the global session is not in *sessions (Manager.cpp:1574-1591); unqueue -> get* throws UnknownId (Manager-Replica.cpp:519). The update lambda (:448-526) has no catch, cluster::guarded only logs; _holding (:465) and _upgradeStarted stay true.
Fix	try/catch per session in holdQueues_; the whole update lambda guarded: on any exception *holding* = *false, releaseHeld*, _upgradeStarted = false, progressEnd
Regression test	`tests/update_stuck.py`

A pattern of deep parentheses overflows the stack of the std::regex compiler: SIGSEGV of the core, from a device

Where	`src/cluster/Tools.cpp:1330` · Crash & DoS · High · pass 4
What it allowed	A paired device with the shell off (`:s/` in a prompt); the global session (schedule_add / task_add with a command and a regex).
Evidence	The executor of libstdc++ 16 is not recursive (the recorded false positive), its compiler is: *M_disjunction -> _M_alternative -> _M_term -> _M_atom -> _M_disjunction for each* `(` *. Patterns from input: substitute* (Prompt.cpp:145, `:s/.../x/`: prompt_refused lets `:s` through for the page) and command_match / command_check (Tools.cpp:1319, 1351).
Fix	One helper for every regex built from input: refuse past a small length (a few hundred characters) or a parenthesis depth (say 64) before std::regex is built. For `:s` from a device, also use a literal replace or std::regex_constants::__polynomial so a pattern cannot run for ever.
Regression test	`tests/regex_limits.py`

Two `usage` requests at once replace a joinable _scanThread: std::terminate, the core gone

Where	`src/cluster/Manager-Usage.cpp:446` · Concurrency · High · pass 4
What it allowed	A paired device sending POST /api/cmd {cmd:usage} from two connections; several interfaces whose panels ask usage at the same moment, with few transcripts (a fast scan).
Evidence	scanTranscripts_ (446-448): `_usageBusy.exchange(true)`, join the old thread, `_scanThread = guarded(...)`. The new thread clears _usageBusy itself when it ends. A short scan ends before the first caller has stored it, so a second caller passes the flag, sees the not yet stored member as not joinable, and one of the two assignments lands on a joinable std::thread: std::terminate.
Fix	A mutex held around the exchange, the join and the assignment (the thread clears the flag just before it ends, so the join is short).

Regression test	`tests/thread_start_race.py`

A callback owed went to the wrong turn: the real answer was never sent

Where	`src/cluster/Manager.cpp:2215` · Logic · High · pass 5
What it allowed	A turn of the user ending while a prompt of the global session waited in the queue used up the callback: the global session got the answer to another prompt and nothing for its own.
Evidence	Reproduced in `tests/callbacks_background.py` (a slow prompt of the user, a question of the global session queued behind it).
Fix	Each turn knows whether a prompt someone waits for was in it; the callback waits for that turn.
Regression test	`tests/callbacks_background.py`

The settings were still written under the threads reading them

Where	`src/cluster/Config.cpp:533` · Concurrency · High · pass 5
What it allowed	The fix of pass 4 published each new version but still copied it into the first object, which the orchestrator, the web access and the tick kept reading directly: a settings change under them, the crash that fix was for.
Evidence	ThreadSanitizer on `tests/config_reload_race.py`: writes in `Config::follow_` against reads in `Orchestrator::handle`, `Web::tick`, `Manager::fireSchedules_`.
Fix	That first object is never written again: every reader goes through `current()`, an immutable version.
Regression test	`tests/config_reload_race.py`

3.3 Medium (79)

`keep_warm_hours` stopped a session with its ♨ still shown

Where	`src/cluster/Manager.cpp:777` · Logic · Medium · pass 1
What it allowed	The cause of the sessions that cooled with ♨ on (s9: last real prompt 21:19:58, stopped 23:19:58). `/keepwarm` did not count as a use. My explanation in 1.9.3 was wrong.
Evidence	`core.log`, `tests/keep_warm_hours.py`.
Fix	`keep_warm_on` for the mark and the wake-up alike; `usedAt` kept; a notice once; `keep_warm_hours = 0` never stops.
Regression test	`tests/keep_warm_hours.py`

The interfaces did not know the time of the cache

Where	`include/cluster/Wire.hpp:32` · Logic · Medium · pass 1
What it allowed	The wire of the sessions lacked `cachedAt`, `usedAt`, `context`: wrong countdown in terminals and windows.
Evidence	Read.
Fix	Added.
Regression test	`tests/keep_warm.py`

`send` against `stop` / `rewind`: a data race on a `std::thread`

Where	`src/cluster/Session.cpp:482` · Concurrency · Medium · pass 1
What it allowed	Joined and replaced by two threads at once: `std::terminate` or a crash.
Evidence	Read.
Fix	`_life` serializes start, stop, take-back; a worker never joins itself.
Regression test	`tests/keep_warm.py`

The fd of a watcher or of a closed stdin could be another file

Where	`src/cluster/WebTty.cpp:345` · Memory · Medium · pass 1

What it allowed	`tell_` wrote 8 bytes to a closed then reused descriptor (a file, a socket, the stdin of an agent); `_in` closed without the lock in `Session::read_` .
Evidence	Read.
Fix	A map fd to session; `_in` closed under the lock.
Regression test	`tests/web_tty_race.py`

`setenv` in a threaded core

Where	`src/cluster/Supervisor.cpp:223` · Concurrency · Medium · pass 1
What it allowed	Another thread asking `data_dir()` meanwhile wrote its state in the wrong instance; `getenv` under `setenv` reads freed memory.
Evidence	Read.
Fix	The environment given on the command line of `env` .
Regression test	`tests/supervisor.py`

A line break in a setting broke `config.toml`

Where	`src/cluster/Settings.cpp:59` · Injection · Medium · pass 1
What it allowed	From a device or the global session: every setting back to its default at the next start, the web gates included.
Evidence	Read.
Fix	`quote_` escapes; `settings_write` checks the result with `Config::check` before replacing it, under a lock.
Regression test	`tests/settings_keys.py`

Hidden files through displays (F3)

Where	`src/cluster/Control.cpp:190` · Files & system · Medium · pass 1
What it allowed	`path` and `paths` of a display were not checked: `~/.ssh/id_rsa` shown to the page or given to the API; `/proc/self/environ` too.
Evidence	`tests/web_gate.py` .
Fix	`hidden_in_` on the whole display, `display_update` too; `hidden_path` follows links and refuses `/proc` , `/sys` , `/dev` .
Regression test	`tests/web_gate.py` , `tests/web_fuzz.py`

The `/tmp/claude-cluster-<uid>` fallback (F4)

Where	`src/cluster/Control.cpp:260` · Files & system · Medium · pass 1
What it allowed	Made before by another user: the socket and the temporary files in their folder.
Evidence	Read.
Fix	Owner checked for the folder and the socket; temporary files in the private runtime folder.
Regression test	`tests/web_fuzz.py`

An API key on a command line (F6)

Where	`src/cluster/Tools.cpp:540` · Secrets & crypto · Medium · pass 1
What it allowed	One-shot describe / chat: `env KEY=...` readable by any user in `/proc` .
Evidence	Read.
Fix	A private file read and removed by `sh` .
Regression test	`tests/one_shot.sh`

`task.expect` read any file under the big lock

Where	`src/cluster/Manager-Tasks.cpp:319` · Crash / DoS · Medium · pass 1

What it allowed	`/dev/zero` : the core frozen then out of memory; `~/.ssh/key` : in a task result.
Evidence	Read.
Fix	A regular file, not hidden, bounded.
Regression test	`tests/tasks.sh`

`capture` kept any output in memory, and could wait for ever

Where	`src/cluster/Tools.cpp:492` · Crash / DoS · Medium · pass 1
What it allowed	`!yes` for 6 hours: the core killed by memory. A program closing its outputs and going on: a thread stuck.
Evidence	Read.
Fix	Its end kept past 64 MB; its end waited for within its time.
Regression test	—

An exception of the file system stopped a tick

Where	`src/cluster/Manager-Schedules.cpp:634` · Crash / DoS · Medium · pass 1
What it allowed	`exists(on.arg)` without an `error_code` (EACCES): `std::terminate` before the guards, the schedules stalled after.
Evidence	Read.
Fix	With `error_code` .
Regression test	`tests/schedule_prompt.py`

Raw images from the page

Where	`src/cluster/Web.cpp:1920` · Files & system · Medium · pass 1
What it allowed	`raw: true` skipped the gates and took any path as an image: any file of the computer sent to the API.
Evidence	Read.
Fix	`raw` removed from what the page sends.
Regression test	`tests/web_gate.py`

A rewind parsed the whole transcript in memory at each wake-up

Where	`src/cluster/Session.cpp:221` · Crash / DoS · Medium · pass 1
What it allowed	Hundreds of MB and seconds in the tick thread: every session waiting.
Evidence	Read.
Fix	A small struct per message; the wake-up out of the tick.
Regression test	`tests/keep_warm.py`

A prompt written to a full stdin held the lock of the session

Where	`src/cluster/Session.cpp:1575` · Crash / DoS · Medium · pass 1
What it allowed	An agent that no longer reads: every interface frozen on `snapshot` .
Evidence	Read.
Fix	Non-blocking, 30 s, then the agent stopped.
Regression test	—

A skill name of a cloned repository used as a path

Where	`src/cluster/Plugins.cpp:249` · Injection · Medium · pass 1
What it allowed	`name: ../../x` in a `SKILL.md` : a symlink made or removed anywhere.

Evidence	Read.
Fix	One component only.
Regression test	`tests/plugins_settings_back.py`

Files of 512 MB read whole per request (F10)

Where	`src/cluster/Web.cpp:337` · Crash / DoS · Medium · pass 1
What it allowed	`/api/file` , `/api/attach/file` , `/app.apk` : 64 connections.
Evidence	Read.
Fix	Streamed by pieces of 1 MB.
Regression test	`tests/web_listen_attach.py`

Logs rewritten with `trunc`

Where	`src/cluster/Session.cpp:1513` · Files & system · Medium · pass 1
What it allowed	A crash in `updateDisplay` or `rewind` : the transcript lost.
Evidence	Read.
Fix	`write_text` : temporary file then rename.
Regression test	`tests/queue_back.py`

`~/.claude.json` rewritten with the default mode

Where	`src/cluster/Manager.cpp:1101` · Files & system · Medium · pass 1
What it allowed	Its account became readable by the other users.
Evidence	Read.
Fix	`write_text` keeps the mode.
Regression test	—

A big paste froze the terminal for a minute, a big image stopped it

Where	`src/cluster/ui/Tty.cpp:8330` · Crash / DoS · Medium · pass 2
What it allowed	5 MB: 85 s, no frame drawn (a regex over the text, every popup checked for each character). `wl-paste` and `magick` ran in the drawing thread. Asked by the user: a popup of progress.
Evidence	`paste_speed2.py` .
Fix	The paste first of all, no regex, its popup with its size; the clipboard in the worker; `Progress.percent` ; the window and the page likewise.
Regression test	`tests/paste_import.py` , `tests/page_import.py`

The letters of a paste were the keys of the popups over the screen

Where	`src/cluster/ui/Tty.cpp:8368` · Logic · Medium · pass 2
What it allowed	The update offer and the lost core read keys before the paste: `q` in a text quit everything, `u` started an update.
Evidence	Read; `tests/paste_import.py` .
Fix	The paste handled first.
Regression test	`tests/paste_import.py`

A big paste closed the WebSocket of the terminal page

Where	`src/cluster/Web.cpp:2342` · Logic · Medium · pass 2
What it allowed	Over 2 MB waiting in its buffer: `gone = true` .

Evidence	`tests/paste_import.py` .
Fix	Its frames handled, the rest read after.
Regression test	`tests/paste_import.py`

A big upload from a phone failed after 60 s

Where	`src/cluster/Web.cpp:226` · Logic · Medium · pass 2
What it allowed	A total deadline whatever the size: 20 MB at 1 Mbit/s never ended.
Evidence	Read.
Fix	60 s + its size at 32 KB/s.
Regression test	`tests/page_import.py`

A big body was read for anyone sending a made up cookie

Where	`src/cluster/Web.cpp:221` · Auth & access · Medium · pass 2
What it allowed	`cc_web=` present was enough: a stranger on the network held 16 to 20 MB per connection for 60 s.
Evidence	`tests/web_gate.py` .
Fix	The real cookies checked before the body; a 401.
Regression test	`tests/web_gate.py`

FTXUI built at -O0 in every installed binary

Where	`CMakeLists.txt:58` · Crash / DoS · Medium · pass 2
What it allowed	`Optimized` is a build type of ours: CMake has no flags for it, `-O2` was on our targets only. Every frame of the terminal and every key ran unoptimized.
Evidence	`flags.make` : `CXX_FLAGS = -std=c++20 -fPIC` ; 100 ms per frame on a 160 x 50 screen.
Fix	`CMAKE_CXX_FLAGS_OPTIMIZED` set before FetchContent.
Regression test	—

A handler of the window that throws ended the window

Where	`src/cluster/ui/Gui.cpp:7584` · Crash / DoS · Medium · pass 2
What it allowed	An exception through the loop of Qt: `std::terminate` , its prompt lost.
Evidence	Read.
Fix	`QApplication::notify` guarded.
Regression test	`tests/gui_shapes.py`

A recording being recognized freezes the core's tick thread: schedules, tasks, keep warm and the quit all wait

Where	`src/cluster/WebVoice.cpp:162` · Crash & DoS · Medium · pass 4
What it allowed	Any use of the page's microphone: the model's first load (~10 s) stalls everything, and a slow CPU stalls every sentence. A paired device can post recordings of up to 16 MB one after another.
Evidence	Path: POST /api/listen -> WebVoice::transcribe holds _mutex for the whole recognition (WebVoice.cpp:111, up to 120 s per recording) -> App ticker (Core.cpp:127-128) runs manager->tick() then web->tick() in one thread -> Web::tick (Web.cpp:663) -> WebVoice::tick locks the same _mutex (155). Reproduced, isolated, with a stand-in voice-listen taking 25 s: a schedule due at +3 s ran 26.5 s after the recording was sent.
Fix	In WebVoice::tick use std::unique_lock with std::try_to_lock and return if not obtained (a recognition running means it is in use).
Regression test	`tests/web_listen_tick.py`

A WebSocket message of the wrong type leaks an eventfd and its terminal session for good

Where	`src/cluster/Web.cpp:2252` · Crash & DoS · Medium · pass 4
What it allowed	A paired device on the terminal port, in a loop. Each message costs one descriptor, so at a soft limit of 1024 the core soon gets EMFILE on accept, state writes and agent spawns.
Evidence	Path: text frame -> `handle` lambda: json.value("t", std::string()) at 2247 throws type_error on {"t":1}, as do json.value("cols",120) at 2249 with a string and json.value("n",0.0) at 2252 -> out of wsLoop_ -> caught in ws_ (2202), so this->_ttys.unwatch(device, watcher) at 2378 never runs. The fd stays open, in session->watchers and in _watched (WebTty.cpp:338-340), which also holds a shared_ptr to the Session.
Fix	Close the watcher with an RAII guard in wsLoop_, or catch std::exception in `handle` and treat the message as malformed.
Regression test	`tests/web_tty_malformed.py`

A device's terminal page sees the code and allows or trusts other devices: `cmd web` has no from_web gate

Where	`src/cluster/Control.cpp:1470` · Auth & access · Medium · pass 4
What it allowed	A paired device with no [web] settings on the terminal page: it reads the code, approves and trusts a second device, and through Web devices can kick, ban or unban others. A lost phone can leave a trusted device behind before it is banned.
Evidence	Path: `--tty` replica (origin web, Manager-Replica.cpp:180) -> web_status() / web_act() (Web.cpp:2102, 2147) -> Control.cpp:1341 `cmd == web` with no from_web check. Control.cpp:622 refuses `action` from the web with `the palette is the user's (its keys, its web access)`, but the popups call `web` directly: Tty.cpp:8370-8390 WebApprove (a / t / d) and Mode::WebDevices.
Fix	In Control `web` : if from_web, allow only a read of `devices` , with `pin` blanked. In Tty, with _webTty, do not open WebApprove / WebDevices and do not show the code.
Regression test	`tests/web_tty_gate.py`

`apply` scope=new writes [agent] permission_mode past [web] settings and the danger confirmation, then reports a failure

Where	`src/cluster/Control.cpp:909` · Auth & access · Medium · pass 4
What it allowed	Any paired device with no [web] settings; the page's own scope popup offers `The next new sub-sessions` (web.html:2872).
Evidence	Path: POST /api/cmd {cmd:apply, kind:mode, value:bypassPermissions, scope:new} (`apply` is in the allowed list, Web.cpp:1588) -> Control.cpp:830-840 has no web_may check -> Manager::applyTo:542-551 -> cluster::settings_set(config, "agent", "permission_mode", ...).
Fix	In Control `apply` : when scope == new and from_web, require cluster::web_may(config, "agent") and the setting_danger confirmation. In applyTo, do not test the return value of settings_set: it says `at next start` , not success.
Regression test	`tests/apply_new.py`

A stranger's UDP flood on the discovery port stops every TCP accept of the web access

Where	`src/cluster/Web.cpp:1002` · Network · Medium · pass 4
What it allowed	Anyone on the LAN, unpaired ([web] discovery is on by default), with a plain UDP loop.
Evidence	serve_ handles only ready.front() (Web.cpp:980-984). While the UDP socket stays readable it stays first, so the listening sockets are never served. found_ runs same_lan_ (getifaddrs) at 1022 before its 0.5 s per-address limit at 1025, so each valid datagram from a LAN address is slow enough to keep up with.
Fix	Handle every event of `ready` , not only the first. Apply the per-address limit, or drop the datagram, before same_lan_; or serve discovery on its own thread.
Regression test	`tests/discovery_flood.py`

Protected program settings reachable under unprotected keys (ui.terminal, user.editor)

Where	`src/cluster/Settings.cpp:722` · Auth & access · Medium · pass 4
What it allowed	The global session (origin mcp) via settings_set; the chosen program then runs as the user when the voice service opens claude-cluster (ui.terminal) or when the user presses Ctrl+E (user.editor). A web device too if [web] settings includes ui/user.
Evidence	setting_protected lists service.terminal and ui.editor (1266), but the settings page exposes the same programs under DIFFERENT keys: ui.terminal (Settings.cpp:138) is read into service.terminal (Config.cpp: `service.terminal = table["ui"]["terminal"]...`) and launched as a command by the voice service (Service.cpp:133-134); user.editor (Settings.cpp:492) is read into user.editor and executed on Ctrl+E (editorCommand_...

Fix	Add ui.terminal and user.editor to setting_protected (and their danger annotations), or key the protected/danger checks on the underlying field rather than the settings-page section.key.
Regression test	`tests/hidden_paths.py`

/export (and :w) with no path writes into a hidden folder via the session name

Where	`src/cluster/Actions.cpp:46` · Files · Medium · pass 4
What it allowed	A web device or the global session: rename to a hidden-folder path, then send /export (or :w) with no explicit path.
Evidence	prompt_refused only checks the export/ `:w` path when `arg` is non-empty (Prompt.cpp:267). run_slash_ "/export" with no arg computes the default path `~/<session name>.md` and writes it with no hidden_path check (Actions.cpp:1354-1358). The session name is attacker-controlled via `rename` .
Fix	Apply the same hidden_path + extension check to the no-arg default path: in run_slash_/ex_ compute the default path then re-run the export gate on it (or gate inside Manager::exportMarkdown's write), not only when the user typed a path.
Regression test	`tests/hidden_paths.py`

Session::restart joins a reader with a live agent while holding _life: stop() waits forever, the core never quits

Where	`src/cluster/Session.cpp:526` · Crash & DoS · Medium · pass 4
What it allowed	The agent of the global session ends by itself and, within that second, a prompt reaches the global session (the user, a sub-session's reply, a schedule). The hang shows at the next quit or update.
Evidence	restart() (:497-499) takes *life and then* `if (_worker.joinable()) _worker.join()` *without checking the agent is still down. The Exited handler sleeps 1 s before calling it (Manager.cpp:1149-1151), and retryGlobal* checks the state before calling it (:944-947). If Session::send restarted the agent meanwhile (:1487-1490), the join only ends when that agent ends.
Fix	In restart(), under _life: return if the session is no longer down (`_in != -1` and state not Stopped/Error); join only then.
Regression test	`tests/session_restart_join.py`

The next notification after gdbus monitor ended assigns over a joinable thread: std::terminate, the core gone

Where	`src/cluster/Manager.cpp:1983` · Concurrency · Medium · pass 4
What it allowed	gdbus monitor ends while the core lives: the session bus restarted, the process killed, a terminal closing on a core that ignores hangup. Then any notification (a turn finished).
Evidence	Line 1785: `if (!_notifyMonitorUp.exchange(true)) _notifyMonitor = cluster::guarded(...)` . notifyMonitor_ sets _notifyMonitorUp=false when gdbus ends or popen fails (:1822, :1870), but nobody joins the thread. std::thread move-assignment onto a joinable thread calls std::terminate. (fake gdbus: `monitor` exits, `call` prints an id): core exit code -6, stderr 'terminate called without an active exception'.
Fix	Join before assigning: `if (_notifyMonitor.joinable()) _notifyMonitor.join();` (it has just ended), or detach the thread at its start.
Regression test	`tests/notify_monitor.py`

A prompt sent while a session is being replaced is answered ok and lost

Where	`src/cluster/Session.cpp:1631` · Data loss · Medium · pass 4
What it allowed	Two requests at once: a page or the global session (parallel tool calls) changing the model / effort / folder or /clear while a prompt is sent. The window is the stop of the agent (up to 3 s). The terminal is not affected, its worker runs them in order.
Evidence	relaunch_ (also clear :351, cd :816, restartGlobal :1702) stops `old` , then replaces it. Manager::send already holds `old` ; Session::send sees down() true, waits on _life, then `old->start()` and dispatches to a new agent of the OLD object (Session.cpp:1487-1499), and that object dies when the last reference is dropped (~Session -> stop). unfinished() was read before, so it is not re-sent.
Fix	Mark the old session retired before stop(): Session::send then throws, and Manager::send gets the new session again. Or serialize relaunch_ and send per session id.
Regression test	`tests/relaunch_prompt.py`

A wake-up takes the output of a !command meant for the next prompt, then the take-back erases it

Where	`src/cluster/Session.cpp:1616` · Data loss · Medium · pass 4

What it allowed	The user runs a !command, then writes no prompt until the next wake-up. Then the agent never sees the output the user wanted to give it.
Evidence	Session::send swaps *context into every prompt (:1471-1476), wake-ups included (Manager::wake* -> send). README and Manager-Replica.cpp:540-543 promise it goes with the next prompt. ([ui] shell_context=always): first wake-up as the agent got it: '<\bash-input>echo MARKER_CTX_OUTPUT<\/bash-input>...[claude-cluster keep-warm: ...]'; after the take-back the next real prompt arrives without it, and it is nowhere in the c...
Fix	In Session::send, do not touch _context when text starts with KEEP_WARM_MARK.
Regression test	`tests/keep_warm_takeback.py`

Keep warm on a per-turn agent (codex, opencode, qwen): every wake-up notifies, against 'A wake-up is silent'

Where	`src/cluster/Session.cpp:564` · Logic · Medium · pass 4
What it allowed	[sessions] keep_warm='all' (or a marked session) with any session on a driver other than claude: a notification about every 4 min.
Evidence	warming is only set in dispatch_ / giveQueued (claude). runTurns_ (:513-523) never sets it, and finished_ builds TurnDone with no warm flag (:569), so event_ takes the full path: notice, notify, sound, replyEnd_, taskDone_. (fake codex, keep_warm='all'): notices grow by 'cx done: ok' at each wake-up, warming false, wake-ups piling in the transcript. README 1554 promises no notification, sound, face, notice nor reply.
Fix	Set warming in runTurns_ from the prompt text and pass warm in the Event of finished_; or do not keep those sessions warm, they have no stream-json prompt cache to keep.
Regression test	`tests/keep_warm_per_turn.py`

The background of a dead agent stays 'running' for ever: no more take-backs, wake-ups pile up, an update waits up to an hour

Where	`src/cluster/Session.cpp:598` · Logic · Medium · pass 4
What it allowed	A claude crash or OOM kill, or a user take-back (Esc), while a background shell or agent runs.
Evidence	finished_ (:546-553) and rewind never touch _data.agents; only task events of that process change a status, and it is gone. So after the agent exits, or after a user rewind (stop() + start() on the same object) with a shell in the background, the status stays 'running'.
Fix	In finished_, under the lock, for a persistent driver: every agent with status 'running' -> 'stopped', ended = now, stopping = false.
Regression test	`tests/background_dead_agent.py`

A prompt starting with the wake-up mark runs silently and is then erased: a paired device can hide what it had the agent do

Where	`src/cluster/Session.cpp:1606` · Auth & access · Medium · pass 4
What it allowed	A paired device (or anything able to send a prompt as it is) on a session kept warm.
Evidence	The wake-up is recognised by its text alone: dispatch_ (:1543), entry_ (:1419), wakeLast_ (:1884), Manager::send (:325, skips the hold of an update). Control's prompt_refused only looks at '!', ':' and '/'. , origin web: send '[claude-cluster keep-warm: delete the files of the build]': run by the agent, notices nothing, and after the next wake-up gone from logs/s1.jsonl with no file in data/rewind and out of the conv...
Fix	Mark it by a private flag instead of the text: a Queued field set only by Manager::wake_, entries recognised by origin + flag; in Manager::send refuse or escape a prompt from outside that starts with the mark.
Regression test	`tests/keep_warm_gate.py`

The terminal page reads and writes the clipboard of the computer

Where	`src/cluster/ui/Tty.cpp:1882` · Secrets · Medium · pass 4
What it allowed	A paired device on the terminal page while the user works at the computer (a password just copied, a paste-jack of the desktop).
Evidence	pty_spawn passes the environment of the core (WAYLAND_DISPLAY too); paste_ runs wl-paste, LineEditor clipboard_ (LineEditor.cpp 78) too, copy_text runs wl-copy (Tty.cpp 2638, 3474, 3488, the copy of a code block, LineEditor Copy / Cut), none tests _webTty.

Fix	When *webTty: no wl-paste / xclip (the page pastes by its own bracketed paste), no wl-copy (OSC 52 only: the clipboard of the device). In copy_text and clipboard* themselves via the environment flag.
Regression test	`tests/web_tty_gates.py`

A question of an odd shape blanks the terminal; `questions: [1]` cannot even be declined

Where	`src/cluster/ui/Tty.cpp:796` · Crash & DoS · Medium · pass 4
What it allowed	An agent's AskUserQuestion. With questions_to_global (default) it lands on the global session, the first screen at each start.
Evidence	Asking::check only requires a non-empty array; Asking.cpp has question_at_ for this, Tty does not: event_ line 8300 and modal_ line 7293 use a.questions[a.index] then .value(). Reproduced with a fake agent: questions [1]: the whole screen is `this screen could not be drawn: type_error.306`, Esc throws before asking.decline() (ask-1 still there), only the quit key works, and it comes back with the popup while the agen...
Fix	Normalise in Asking::check / current (drop non-object questions, strings as {label}); use question_at_ in Tty; try / catch around askPreview_ showing its text; test find_first_not_of against npos at 4553.
Regression test	`tests/question_shapes.py`

A paste in a text field is replayed key by key: the terminal frozen, no frame, no popup

Where	`src/cluster/ui/Tty.cpp:8223` · Crash & DoS · Medium · pass 4
What it allowed	The user pasting a path, an id or a long line in Ctrl+K, Ctrl+F, Ctrl+R, the settings search; a device on the page too.
Evidence	pasted_ calls event_(Character) for each character, its comment says the opposite ("given at once"): each one runs shownRefresh_, filter_, searchUpdate_, historyFilter_, settings_search, setting_suggestions. Measured: palette, near empty config: 100 characters 5.1 s, 2000 characters more than 100 s with no frame; search of a transcript of 2 MB: 2000 characters 35 s.
Fix	Insert the whole text in the field (as the Question branch does: field_(value).insert(text), value = its text) and run its filter once.
Regression test	`tests/paste_fields.py`

A paste in the chat of a question goes to its answer; on the review it changes an answer

Where	`src/cluster/ui/Tty.cpp:8214` · Logic · Medium · pass 4
What it allowed	The user pasting in the chat: the text meant as a question to the side chat becomes the answer selected for the agent.
Evidence	The Question branch of pasted_ never looks at _askChat or ask->review. Reproduced: Ctrl+T (`chat ›` open), paste: core says other = 'pasted-for-the-chat', cursor 3 (moved to Other), the chat field stays empty while typed keys do reach it. README line 131 lists the chat among the fields taking the bracketed paste.
Fix	if (_askChat) {_askDraft.insert(text, keeping its line breaks); return;} if (ask->review) refuse with the note of the popups of keys.
Regression test	`tests/paste_fields.py`

The labels of earlier prompts stay live: an old paste or image goes to another session

Where	`src/cluster/Editor.cpp:520` · Logic · Medium · pass 4
What it allowed	A text holding `[Image #N]` or `[Pasted text #N ...]` (typed, pasted, a file read, a prompt back) after an earlier prompt in that interface.
Evidence	Editor::clear only moves _firstAtom, atoms stay, and atomize loops over all of them. Reproduced in the terminal: a block of SECRET lines sent to s1; on s2 `:r notes.txt` whose text only quotes `[Pasted text #1 +5 lines]`, Enter: fake.log holds the secret again (count 2 -> 4), so the agent of s2 got it.
Fix	atomize from _firstAtom only (the atoms of the prompt being written).
Regression test	`tests/prompt_edit_shapes.py`

The start menu deletes an instance whose state.json does not parse, or whose sessions are all archived

Where	`src/cluster/StartMenu.cpp:105` · Data loss · Medium · pass 4
What it allowed	Opening the terminal: a state.json damaged (the save race of older versions, a full disk), or an instance whose sessions were closed to the trash.

Evidence	start_menu: not alive and previous_() == 0 -> remove_all(instance). previous_ returns 0 on any read_json failure, and counts `sessions` only while the trash lives in state.json under `trash` (Manager.cpp 1398). Reproduced: instances/broken with a truncated state.json and logs/, instances/archived with {"sessions": []}: both folders gone as soon as the menu is shown, no question.
Fix	Remove only a state.json that parses and has no sessions, no trash and no logs; an unreadable one is listed, never deleted.
Regression test	`tests/start_menu.py`

On the terminal page every action of a key is refused: new session, interrupt, allow / deny

Where	`src/cluster/Control.cpp:165` · Logic · Medium · pass 4
What it allowed	Any device using the terminal page, every time.
Evidence	A web terminal's Manager::call adds origin web (Manager-Replica.cpp 180); run_ -> run_action_ -> cmd action -> `if (from_global || from_web) throw "the palette is the user's"`. Reproduced: Ctrl+T Enter on the page: status `the palette is the user's (its keys, its web access)`, no session; F8 the same; the same keys on a real terminal work.
Fix	In Control, from_web: an allow-list of action ids matching the API of the page (new_session, interrupt, allow, always, deny, resume, send_next, close_session, rename, describe, mode:*, model:*...), the rest still refused.
Regression test	`tests/web_tty_gate.py`

Any segfault of the terminal thread becomes an endless loop: no exit, no reset, no draft

Where	`src/cluster/ui/Tty.cpp:9109` · Crash & DoS · Medium · pass 4
What it allowed	Any memory error on the drawing thread, whatever its cause.
Evidence	run_tty installs terminal_fatal_, then ScreenInteractive::Loop replaces it with ftxui RecordSignal, which only records and returns: the faulting instruction runs again for ever. Seen in the `:` reproduction: stack RecordSignal <- __restore_rt <- the faulting frame, thread state R, CPU used, the terminal left in raw + mouse mode, never killed, no core dump, draftKeep_ never reached.
Fix	Install terminal_fatal_ again once the loop runs (first event in CatchEvent) for SIGSEGV, SIGBUS, SIGILL, SIGFPE, with SIG_DFL + raise as it does.
Regression test	`tests/tty_fatal.py`

While the restore question waits, queued tasks fail and due one-time schedules are consumed

Where	`src/cluster/Manager-Tasks.cpp:391` · Data loss · Medium · pass 4
What it allowed	Any restart with restore = ask and a task queued (a running one becomes queued) or a schedule due
Evidence	tick runs schedule_ / fireSchedules_ while *restoreAsk; only releaseHeld* checks it (:1518, its comment says why). With restore = ask (the default) and serve --linger (Core.cpp:708) the sessions are still in *previous: schedule* fails the task (Manager-Tasks.cpp:451, :428), runSchedule_: send throws (Manager-Schedules.cpp:423), caught :499, then advance_(fired) ends it.
Fix	if (!_holding && !_restoreAsk) in tick; clear _restoreAsk after restorePrevious
Regression test	`tests/restore_answer.py`

A task started while an update waits runs twice after the switch

Where	`src/cluster/Manager-Tasks.cpp:390` · Logic · Medium · pass 4
What it allowed	A task added, or a dependency ending, during the wait of an update
Evidence	schedule_ has no *holding check, only the tick does; addTaskJson (:173), taskDone* (:334), taskAct, pollEvents_ call it directly. Status running, send -> hold_ returns normally (Manager.cpp:325), the prompt is in held.json. New version: load -> queued -> sent (Manager.cpp:1368), then releaseHeld_ sends the held copy (Manager.cpp:1520).
Fix	if (this->*holding) return; at the top of schedule*
Regression test	`tests/task_restart.py`

Cron with days / window: next_after_ gives up after 60 occurrences, the schedule is refused or ends for good

Where	`src/cluster/Manager-Schedules.cpp:72` · Logic · Medium · pass 4
What it allowed	Any schedule whose cron is denser than its days / window

Evidence	Loop of 60 cron_next, 0 when all are outside the rules: bad("never fires") at creation (:177), end("no next time") in advance_ (:443). Reproduced: cron */5 * * * * with a window opening in 8 h: refused; * * * * * with a window closing in 2 min: after 1 run status done, reason "no next time".
Fix	Outside the rules: jump with time_next_allowed, cron_next from there; bound by a date (a year), not a count
Regression test	`tests/schedule_rules.py`

Weekday 7 means every day, 5-7 loses Sunday

Where	`src/cluster/Cron.cpp:161` · Logic · Medium · pass 4
What it allowed	A cron or days rule using 7 as written in most crontabs
Evidence	Item "7": from = to = 7; :135 to = 6, :136 from = 0: 0..6 all marked (the comment says 7 = Sunday). "5-7": to = 6, Sunday never marked. Reproduced with dry_run: 0 9 * * 7 -> 11-03, 11-04, 11-05, 11-06, 11-07; 0 9 * * sun -> Sundays; 0 9 * * 5-7 -> Fri, Sat only; days "7": every day. A weekly prompt costs tokens 7 times a week.
Fix	Accept 0..7 and mark v % 7 for each value
Regression test	`tests/schedule_rules.py`

A queued cluster-run runs at once, unthrottled, at any core restart: its 30 s count from its start

Where	`src/run/cluster-run.cpp:407` · Logic · Medium · pass 4
What it allowed	A core restart, a crash or an update with wrappers waiting in the queue
Evidence	began is set once (:381); after a lost connection :453 compares with it, so a job queued for more than 30 s runs directly without retrying. docs/orchestrator.md:135: "when the connection drops while queued it retries for 30 s".
Fix	A clock restarted at each loss of the connection
Regression test	`tests/cluster_run_requeue.py`

A queued job that cannot start is never told to its owner

Where	`src/cluster/Orchestrator.cpp:721` · Logic · Medium · pass 4
What it allowed	jobs_add with a folder gone, a sh not found, no pipe left; the agent ended its turn as told
Evidence	spawn_ sets job.state = failed (:785, :721) before finish_ (:788), and finish_ returns at once on an ended job (:856): no callback, no touch_. Reproduced: max_jobs 1 busy, job_add with a missing cwd, callback on: the answer says "you are woken up with [job j2 ...]", once the slot frees state failed "not started", the session gets nothing.
Fix	Set only the reason and let finish_ set the state, in both paths
Regression test	`tests/job_end_told.py`

if.usage with a long number stops every later schedule for ever

Where	`src/cluster/Manager-Schedules.cpp:98` · Crash & DoS · Medium · pass 4
What it allowed	A paired device (schedule_add carries no command), a sub-session with sub_schedules, the global session
Evidence	usage_cond_check_ (:86) accepts any digits; std::stod throws out_of_range (:373); conditionMet_ is outside the try of runSchedule_ (:492); the catch of the thread (:735) frees busy without advancing and bgPass_ (:618) drops the rest of its list, each second again. Reproduced: schedule_add if {usage:"5h>1"+"0"*400}, then a plain one at +2 s: 8 s later both waiting, runs 0, no prompt.
Fix	Bound the digits in the pattern or parse without throwing; in bgPass_, a try per schedule that advances it
Regression test	`tests/schedule_rules.py`

A long window list freezes the manager lock: 1.2 KB, 20 s; 1 MB, hours

Where	`src/cluster/Cron.cpp:241` · Crash & DoS · Medium · pass 4
What it allowed	A paired device, a sub-session with sub_schedules, the global session
Evidence	window / quiet have no bound; ranges_ builds a std::regex per item at each call (:239), time_next_allowed calls time_allowed per minute (:286, up to 11520), and advance_ does it under Manager::_mutex (Manager-Schedules.cpp:505 -> :442). Reproduced: page, 100 ranges (1199 bytes), every 1: task_list answered in 20.8 s when the window closed, every request on the lock waiting. Linear in the size.

Fix	Bound window / quiet / cron (16 ranges, 256 bytes), parse once with a static regex, compute the next time out of the lock
Regression test	`tests/schedule_rules.py`

task expect gives a device any non-hidden file, where :r is refused

Where	`src/cluster/Manager-Tasks.cpp:127` · Secrets · Medium · pass 4
What it allowed	A paired device with [web] shell off, any folder out of the hidden ones
Evidence	taskDone_ reads the file of `expect` into the result with hidden_path as its only check; the gate of the page (Control.cpp:538) only looks for commands, task_list is allowed. Reproduced, shell off: :r /etc/hostname refused; task_add {target, expect:"/etc/os-release"} -> task_list result "[file /etc/os-release]\nNAME=\"Fedora Linux\"...". The agent is also told to write its result to that path (:562).
Fix	From the page: the gate of :r for expect, or a path inside the folder of the session only
Regression test	`tests/task_expect_page.py`

A prompt kept in a queue over a restart is lost when a limit refuses it

Where	`src/cluster/Manager-Schedules.cpp:791` · Data loss · Medium · pass 4
What it allowed	A restart or update with prompts queued and a spending limit reached
Evidence	handoff_ sends with force = false; Manager::send refuses on [limits] block or budget (Manager.cpp:332-342), the catch is empty, queued.erase follows (:679). README: queues "are sent again to their session". Reproduced: queued prompt in state.json, daily limit reached at restart: notice "prompt refused", nothing to the agent, queued null in state.json, nothing at the next start. releaseHeld_ uses force = true.
Fix	force = true as releaseHeld_, or keep the entry when it is refused
Regression test	`tests/handoff_limit.py`

F9 of the supervisor: heap use after free on each value edited

Where	`src/cluster/Supervisor.cpp:1021` · Memory · Medium · pass 4
What it allowed	The user editing any non-bool setting in F9 of the terminal supervisor
Evidence	set_web takes const Setting& s; :1390 passes webList[webAt]; :998 webList = web_settings() frees it; :999 reads s.label (:1407 copies, :1390 does not). Reproduced: --supervisor --tty, F9, Enter, Enter: heap-use-after-free READ of size 8 in supervisor_tty $_8, exit 1. Normal build: a garbled note or a crash.
Fix	const cluster::Setting setting = webList[webAt]; at :1390, as :1407
Regression test	`tests/supervisor_safe.py`

Threads of the supervisor outlive its frame: stack writes in the interface opened after it

Where	`src/cluster/Supervisor.cpp:852` · Memory · Medium · pass 4
What it allowed	An action still running (w up to 10 s, force up to 25 s, P) when the user opens an instance from the supervisor
Evidence	background detaches a thread capturing [&] (:919: note, mutex, screen), so does P (:1515); supervisor_tty returns while it runs and Core.cpp:618-625 goes on as the interface of the instance chosen. Reproduced: w, then Enter, Down, Down, Enter (Start and open it): stack-use-after-return in supervisor_tty $_0, thread T4. Normal build: note = ... and a mutex lock on dead stack of the running interface.
Fix	The shared state in a shared_ptr captured by value, or the threads joined before the return
Regression test	`tests/supervisor_safe.py`

A cycle of parentUuid in a transcript multiplies its text 100000 times in memory

Where	`src/cluster/External.cpp:128` · Crash & DoS · Medium · pass 4
What it allowed	A file under ~/.claude/projects written by an agent (a file of another tool, not trusted), then the page, a terminal or the global session opening it (import, context claude:), or messages / edit on a session on it.
Evidence	claude_entries_ follows parentUuid with only `chain.size() < 100000` as a bound (External.cpp:126). A cycle gives 100000 pointers to the same lines, then entries.push_back copies each text. external_entries trims to 400 only after that (External.cpp:333). branch_ does the same with copies of whole JSON lines (Manager-External.cpp:95-96).

Fix	Bound both loops by the messages read: `chain.size() < messages.size()` , as rewind_point_ does.
Regression test	`tests/transcript_cycle.py`

session_edit writes the edited conversation readable by every user

Where	`src/cluster/Manager-External.cpp:374` · Files · Medium · pass 4
What it allowed	Any edit of a conversation: the user or the global session (session_edit, with [sessions] global_edit).
Evidence	editConversation: std::ofstream out(path.parent_path() / (conversation + ".jsonl")): mode from the umask, in ~/.claude/projects/. Claude Code keeps its transcripts 0600 in folders of mode 0755 (seen on this computer: ~/.claude/projects drwxr-xr-x, files -rw-------).
Fix	Build the text, then cluster::write_text(new path, text): 0600 for a new file, atomic, its failure told.
Regression test	`tests/conversation_edit_mode.py`

The cwd of a file display walks past the hidden check: hidden images and PDFs previewed

Where	`src/cluster/Display.cpp:349` · Auth & access · Medium · pass 4
What it allowed	The global session (display, display_update), or a session whose folder is hidden with a relative path. A device gets the same through pin.
Evidence	hidden_in_ (Control.cpp:146) checks `path` and `paths` as written, relative to the cwd of the core. display_prepare joins a relative path to the `cwd` field given in the same display (Display.cpp:335, 345), and Manager::display defaults it to the session folder (Manager-External.cpp:415). cwd itself is never checked. The file card then carries path, size and a base64 preview (Display.cpp:352-364).
Fix	In the `file` loop of display_prepare, when the caller is gated, check hidden_path on the joined canonical path before reading a preview; or have hidden_in_ also refuse a hidden `cwd` and judge relative paths against that base.
Regression test	`tests/display_file_cwd.py`

hidden_path resolves links after a lexical `..`: a link followed by .. reaches a hidden folder

Where	`src/cluster/Tools.cpp:932` · Auth & access · Medium · pass 4
What it allowed	The global session or a device, when any folder link into a hidden tree exists outside hidden folders (a dotfile manager, ~/Games into ~/.local, one an agent made).
Evidence	full = absolute(...).lexically_normal(); real = weakly_canonical(full). `/tmp/link/../id_rsa` becomes `/tmp/id_rsa` before any link is resolved, while the kernel goes link -> /.ssh/sub, then .. -> /.ssh, then id_rsa. So the comment `a link to ~/.ssh is ~/.ssh` does not hold when `..` follows the link.
Fix	real = weakly_canonical(absolute(expand_home(path))): the path as written, not its normalized form; keep the lexical form as the second check.
Regression test	`tests/hidden_paths.py`

The token in a git remote URL goes to machine.md, the model and the page

Where	`src/cluster/Machine.cpp:343` · Secrets · Medium · pass 4
What it allowed	Any repository cloned with a token in its URL (common with CI tokens), once the map of this computer is made: the global session sends it to its API, a paired device reads it.
Evidence	repository_ keeps `url = (\S+)` of .git/config whole (Machine.cpp:351), machine_scan writes it in the Projects table (625). machine_scope promises `no file content` and the global session reads machine.md; cluster::projects reads it back and Control.cpp:816 gives `origin` to the `projects` command of the page.
Fix	Remove the user information of the URL before keeping it (`://[^/@]*@ -> ://`).
Regression test	`tests/machine_origin.py`

~/.claude/settings.json of an unexpected shape makes `list` and `read` fail, on the page too

Where	`src/cluster/Tools.cpp:599` · Crash & DoS · Medium · pass 4
What it allowed	A file of another tool (Claude Code, an agent editing its settings) with a non-string level or model.

Evidence	claude_default_effort: value.value("effortLevel", std::string()) throws type_error when the level is not a string (line 636); claude_default_model_read_ does the same on `model` (line 586). effort_label calls it from Manager::toJson (Store.cpp:265), so every request listing sessions fails for as long as the file stays so.
Fix	Read them only when they are strings: `value["effortLevel"].is_string()` , `settings["model"].is_string()` .
Regression test	`tests/claude_settings_shape.py`

loadContext reads a whole file to keep its last 60000 bytes

Where	`src/cluster/Manager-External.cpp:228` · Crash & DoS · Medium · pass 4
What it allowed	The global session (a session_context on a disk image, a log, a sparse file an agent made).
Evidence	EXT-2 made it a regular file, not a bounded one: content.assign(istreambuf_iterator, ...) reads everything (line 226), then line 229 cuts it to 60000. `:r` and task.expect were capped, this one not. Reproduced on an isolated core under RLIMIT_AS 2 GB: sparse 900 MB file: `bad request: std::bad_alloc` after 21 s; 8 GB the same.
Fix	Read only the end: seek to size - 60000, read that much.
Regression test	`tests/context_big_file.py`

A tree display and the git panel run the commands of the folder's .git/config

Where	`src/cluster/Display.cpp:636` · Injection · Medium · pass 4
What it allowed	A folder with a crafted .git/config: an archive unpacked, or an agent allowed to edit files but not to run commands writing it. Then a display of a tree, or the git / diff panel of the session.
Evidence	display_prepare runs `git -C <path> status --porcelain` (Display.cpp:211), and Git::read runs git rev-parse / log / diff HEAD in the session folder (Git.cpp:37-45), with no -c override, so the folder's core.fsmonitor runs, plus diff.external by reading.
Fix	`git -c core.fsmonitor=false -c core.hooksPath=/dev/null ...` for these read commands, and --no-ext-diff --no-textconv on the diffs.
Regression test	`tests/display_git_config.py` , `tests/git_panel_config.py`

The output file of a background shell was read whole at every frame

Where	`src/cluster/ui/Tty.cpp:6621` · Crash / DoS · Medium · pass 6
What it allowed	A shell writing a big log (a build, tests, gigabytes of it) made each frame of the list allocate and read the whole file: in the terminal, the window and the `agents` request. A fifo named as its output file blocked that thread for ever.
Evidence	`tests/callbacks_background.py` : a 64 GB file with a hole answers at once with its end, a fifo answers empty.
Fix	`read_end` : a regular file only, opened without blocking, its last bytes by `pread` ; the whole-output view stops at a megabyte.
Regression test	`tests/callbacks_background.py`

A fix of this audit gave the end of a shell's output to the model as words of the user

Where	`src/cluster/Session.cpp:1259` · Injection · Medium · pass 6
What it allowed	Pass 5 kept the end of a shell's output for its log, and that text also went in its `<task-notification>` prompt: what a process printed (a page it downloaded) reached the model as if the user had said it. Never released.
Evidence	Found reading the fixes again; `tests/callbacks_background.py` : a shell saying nothing, its output not in the prompt.
Fix	The prompt has what claude says of the task and the path of its file (the model reads it as a tool result); the end of its output is a line of the conversation.
Regression test	`tests/callbacks_background.py`

A fix of this audit left readers on the settings of the start

Where	`src/cluster/Store.cpp:268` · Logic · Medium · pass 6
What it allowed	Pass 5 stopped writing the first object of the settings; what still read it saw the values of the start for ever, with no error: the list of the sessions (keep warm, effort), the stash and history limits, the voice service, `machine --scan` . Never released.
Evidence	`tests/keep_warm.py` failed in the confirmation run: `keep_warm` listed false with `keep_warm = "chosen"` in the file.
Fix	Those readers go through `current()` ; a test fails if a direct read of that object comes back in the sources.

Regression test	`tests/keep_warm.py` , `tests/config_reload_race.py`

A background task ending during another turn was told to nobody

Where	`src/cluster/Session.cpp:1256` · Logic · Medium · pass 5
What it allowed	Its result reached the model in that turn (the user's, or a keep-warm wake-up, which then told nothing and could be taken back), and the session that was waiting for it was never told.
Evidence	`tests/callbacks_background.py` : a shell ending during a turn of the user.
Fix	The end of that turn is its result: told to whoever follows the session, never silent, never taken back.
Regression test	`tests/callbacks_background.py`

An agent gone after its answer: nobody told what stopped with it

Where	`src/cluster/Session.cpp:612` · Logic · Medium · pass 5
What it allowed	The callback was used by its first answer ("the build runs, its result follows"): when the agent then died, its background with it, `[stopped: ...]` was not sent and the global session waited for ever.
Evidence	`tests/callbacks_background.py` : an agent exiting after that answer.
Fix	Told to whoever follows it, with what stopped; a line of the conversation.
Regression test	`tests/callbacks_background.py`

The end of a background task was dropped when it was not recognized

Where	`src/cluster/Session.cpp:1199` · Logic · Medium · pass 5
What it allowed	A kind of task not known here, a task started before a core restart, or an end told by `task_updated` alone: no wake-up, the session idle, its result never read.
Evidence	`tests/callbacks_background.py` , one case each.
Fix	Any end is an end. For a task never seen starting a moment is left, for a Monitor that starts its own turn (`tests/callbacks.sh`), then the session is woken.
Regression test	`tests/callbacks_background.py` , `tests/callbacks.sh`

A wake-up a session asked for itself did not tell its result to its parent

Where	`src/cluster/Session.cpp:200` · Logic · Medium · pass 5
What it allowed	A schedule or a task a session gave itself to look again later ran, and its answer stopped there: the session that was waiting heard nothing.
Evidence	`tests/callbacks_background.py` : a schedule, a task for itself.
Fix	The end of those turns goes to whoever follows the session, as for a background task done.
Regression test	`tests/callbacks_background.py`

A question of an odd shape still threw inside the core

Where	`src/cluster/Asking.cpp:42` · Crash & DoS · Medium · pass 5
What it allowed	The fix of pass 4 protected the drawing in the terminal, but the core read the same fields raw: a `multiSelect` of another type or a number for a text made every answer fail, the question could not even be declined.
Evidence	`tests/question_shapes.py` : `bad request: type must be boolean, but is string` .
Fix	Each question put in one shape when it is offered, the notification and the update reading the raw one guarded.
Regression test	`tests/question_shapes.py`

The web access and the voice were pointers read by every thread with no synchronization

Where	`include/cluster/Manager.hpp:250` · Concurrency · Medium · pass 5
What it allowed	A request arriving during the start read an object still being built, one arriving at the quit a pointer being cleared.

Evidence	ThreadSanitizer: `Manager::syncState` against `Core::ui_` and `App::stop`.
Fix	Atomic pointers, the object published once built.
Regression test	`tests/web_gate.py`

The session shown was a string written by an interface while the orchestrator read it

Where	`include/cluster/Manager.hpp:173` · Concurrency · Medium · pass 5
What it allowed	A string copied while it is assigned: a crash, or a heavy job ranked on garbage.
Evidence	ThreadSanitizer: `Manager::noteActive` against `Manager::active` in `Orchestrator::second_`.
Fix	Its own lock, every reader through `active()`.
Regression test	`tests/web_gate.py`

The git panels ran what the `.git/config` of the folder asks

Where	`src/cluster/Git.cpp:38` · Injection · Medium · pass 5
What it allowed	`Git.cpp` was still calling plain `git`: opening an archive or a folder an agent wrote in ran its `core.fsmonitor`, its filters, its external diff, its hooks.
Evidence	Armed repositories in `tests/git_panel_config.py`: the marks of `clean`, `fsmonitor`, `gpg`, `hook`, `textconv`, `external` and `lazy` appeared.
Fix	Every read of the panels by `git_read`, as the tree display.
Regression test	`tests/git_panel_config.py`

3.4 Low (62)

Finding	Where	Category	What, the fix	Test	Pass
`Host` with a CR, `cc_dev` of any shape, a mime with a line break	`src/cluster/Web.cpp:471`	Injection	Header injection in a redirect or in `/api/file` by what an agent wrote. `host_clean_`, hex only, the mime checked.	`tests/web_gate.py`	1
`_certWhy` written and read without a lock	`src/cluster/Web.cpp:1070`	Concurrency	A race on a `std::string`. Under the lock.	—	1
A notification under the lock of the web access	`src/cluster/Web.cpp:2041`	Crash / DoS	`gdbus` waiting: every request and interface waiting. Out of the lock.	—	1
No thread or descriptor left: an exception, a spinning loop	`src/cluster/Web.cpp:624`	Crash / DoS	`std::system_error`; `accept` EMFILE at 100 % CPU. Guarded, a pause.	`tests/web_fuzz.py`	1
Generators shared by threads	`src/cluster/Attachments.cpp:57`	Concurrency	`mt19937` without a lock in `new_id_` and `uuid_`. `thread_local`.	—	1
`prepare_` looped for ever on a path holding its token	`src/cluster/Session.cpp:154`	Crash / DoS	`[Image #1]` in the path of the image. Searched after what it put.	—	1
`Vt` counts and escapes without a bound	`src/cluster/Vt.cpp:254`	Crash / DoS	`ESC[9999999999S` under the session mutex; an endless escape. Clamped.	`fuzz_parsers`	1
Temporary files in `/tmp` with fixed names	`src/cluster/Tools.cpp:914`	Files & system	`say`, `play`, display files readable and guessable. The private runtime folder.	—	1
A socket of another user was talked to	`src/cluster/Control.cpp:67`	Auth & access	Prompts sent to a socket made by another user in the fallback folder. `connect_` checks the owner, `cluster-run` too.	—	1
`exportMarkdown` took any id	`src/cluster/Store.cpp:101`	Files & system	`../` to any `.jsonl`. The id checked.	—	1
`restore` lost a session when its agent was gone	`src/cluster/Manager.cpp:589`	Logic	Erased from the trash before `make_` failed. Put back.	—	1
`settings_set` took any value	`src/cluster/Settings.cpp:965`	Logic	A choice out of its list written. `setting_check`.	`tests/settings_keys.py`	1
Tokens compared with `==` (F9)	`src/cluster/Web.cpp:108`	Secrets & crypto	Timing. `same_secret_`.	—	1

Finding	Where	Category	What, the fix	Test	Pass
`config_write` not atomic	`src/cluster/Control.cpp:1060`	Files & system	A config read half written. `write_text` .	`tests/prompt_write.sh`	1
`magick` without a limit	`src/cluster/Attachments.cpp:194`	Crash / DoS	A pixel bomb from a device. `-limit memory / map / disk` ; kept as it is on failure.	—	2
A line of another tool failed the whole list of conversations	`src/cluster/External.cpp:289`	Logic	One bad line in `~/.claude/projects` : nothing listed. Per file.	—	2
`hold_` could lose a prompt during an update	`src/cluster/Manager-Upgrade.cpp:169`	Concurrency	Read, added, written by several threads. A lock.	`tests/update_hold.py`	2
The flags of a `!command` read out of the lock	`include/cluster/Manager.hpp:80`	Concurrency	`/kill` and its thread. Atomics.	—	2
What is copied on the command line of `wl-copy`	`src/cluster/ui/Tty.cpp:1883`	Secrets & crypto	Readable in `ps` ; past 128 KB refused while `copied` is said. `copy_text` : a memfd on its input.	—	2
A paste without a bound, or without an end	`src/cluster/ui/Tty.cpp:437`	Crash / DoS	All the memory by a device of the terminal page; an end lost: every key swallowed for ever. 64 MB, told; 10 s without any of it: ended.	`tests/paste_import.py`	2
The polling terminal lost a paste over 1 MB	`templates/tty.html:303`	Logic	Refused without a word. By pieces.	`tests/page_import.py`	2
The first upload after a start refused	`src/cluster/Web.cpp:1620`	Logic	`attach_cap_` set after the request was read. Before.	—	3
A stale worker id refused a prompt	`src/cluster/Session.cpp:520`	Concurrency	A thread id reused after a join looked like the worker joining itself. Found in my own fix of pass 1. Reset when it ends.	`tests/keep_warm.py`	3
`_warmMissed` used by the tick and by a wake-up	`src/cluster/Manager.cpp:849`	Concurrency	A race in my own fix of pass 1. Under the lock.	—	3
The draft of a prompt of megabytes written in the drawing thread	`src/cluster/ui/Tty.cpp:1630`	Crash / DoS	A pause at each change. In the worker; its last word at the quit.	`tests/paste_import.py`	3
A request of megabytes searched from its start for each piece	`src/cluster/Control.cpp:118`	Crash / DoS	Quadratic: 30 s on 64 MB. What came only.	`tests/paste_import.py`	3
A line of an agent without an end	`src/cluster/Session.cpp:449`	Crash / DoS	All the memory. 512 MB, dropped.	—	3
A question of an agent on the page wiped what was being typed at each refresh	`templates/web.html:2576`	Logic	On the page and the app, the Other answer of a question was drawn again at each refresh of the state: its text, the focus and the caret lost while typing. What is typed is kept by question (`askTyped`), the box drawn again only when the question changes, Other sent to the core debounced so that every interface finds it.	`tests/page_question.py`	3
A markdown display of an agent can hang the page: the link regex is quadratic on `[`	`templates/web.html:1829`	Crash & DoS	An agent displays {type:markdown, text:"[[[[..."} of a few hundred KB. Any device showing that session hangs. Put in the global session, the page hangs at each load, since it opens on it. Bound the link: /[([^]\n]{1,500})](.../, or parse with a linear scan, and cap the length of a line given to inlineMarkdown.	`tests/page_markdown.py`	4
The terminal of an open page is killed after 2 minutes on a quiet screen	`src/cluster/Web.cpp:2318`	Logic	A terminal page left open on a screen that does not change for 2 minutes. Refresh the session's seen in wsLoop_'s once-a-second device check (a small WebTty::touch(device)).	`tests/web_tty_quiet.py`	4
The slow-upload fix stops at 1 MB: a body just under it fails on a link where a bigger one succeeds	`src/cluster/Web.cpp:226`	Logic	A phone uploading a 600 KB - 1 MB body at under 100 KB/s, which fails with `the connection was lost` . Extend the deadline for any body read for a connected device: once device(request) passed (length > 4096), end = now + 60000 + length / 32.	`tests/web_slow_upload.py`	4

Finding	Where	Category	What, the fix	Test	Pass
send_next with the agent down takes the queued prompt out and loses it	`src/cluster/Session.cpp:1893`	Data loss	The agent dies during a turn with a prompt queued, and the user presses F8 / send_next (or the page). Before the pop: `if (_in == -1)` throw, or start the agent as send does (from a thread that may join), leaving the queue untouched.	`tests/send_next_down.py`	4
Esc takes back the wake-up instead of the user's prompt and fills the editor with the keep-warm text	`src/cluster/Session.cpp:1928`	Logic	Keep warm on, idle more than ttl-margin, then 'take back my last prompt' on the window or the page; the terminal chooser lists the wake-up as a point. For byUser: a wake-up last is cut together with the prompt before it; rewind_points skips wake-ups, keeping the `back` counts consistent.	`tests/keep_warm_takeback.py`	4
keep_warm from a paired device writes [sessions] keep_warm past [web] settings	`src/cluster/Prompt.cpp:255`	Auth & access	A paired device without settings rights turns keep warm on: the mode changes on the computer and tiny turns are billed every few minutes for up to keep_warm_hours after the last use. In the keep_warm branch: if from_web, the mode is off and ! web_may(config, "sessions"), refuse; the per-session mark can stay allowed when the mode is already on.	`tests/keep_warm_gate.py`	4
With a text field open, the letters of a paste still answer the popups over the screen	`src/cluster/ui/Tty.cpp:8191`	Logic	A paste in Ctrl+K, Ctrl+F, Ctrl+R, a form, the settings search while the core is lost or a failure is shown. The direct insertion above; or at the top of pasted_: lost or a failure shown -> refused with the note.	`tests/paste_fields.py`	4
_fieldsDrawn is cleared only when the title changes: clicks swallowed after a popup, the list grows	`src/cluster/ui/Tty.cpp:7984`	Logic	Any popup with a field, then a click where it was; a popup left open grows the list at 25 entries per second. Move this->_fieldsDrawn.clear() out of the if.	`tests/paste_fields.py`	4
The draft kept in the worker (pass 3 fix) is lost at a quit when a job runs	`src/cluster/ui/Tty.cpp:1615`	Data loss	A quit within a job of the worker (a send starting an agent, a clipboard import) with a prompt typed meanwhile. draftKeep_(true) always saves (no test against _draftSaved), or _draftSaved set inside the job.	`tests/prompt_draft.py`	4
The new paste rule refuses a path dropped on the plugins page	`src/cluster/ui/Tty.cpp:8281`	Logic	A folder or .zip dropped or pasted on the sources list in a terminal sending it as a bracketed paste. Plugins, sources list: open _plugAdd and insert the pasted text.	`tests/paste_fields.py`	4
The vim motion `e` stops inside a UTF-8 character: the prompt sent is corrupted	`src/cluster/Editor.cpp:742`	Data loss	The user in vim mode with accents in the prompt. After the motion, back to the start of the character (or step with next_); the same for the column of j / k.	`tests/prompt_edit_shapes.py`	4
A big vim count freezes the terminal	`src/cluster/Editor.cpp:82`	Crash & DoS	Digits typed in vim Normal; a device of the terminal page burns a core of the computer per terminal. Break when p is unchanged; cap the count (a few thousands).	`tests/prompt_edit_shapes.py`	4
audio_seconds_ reads 3 bytes past the end of a WAV	`src/cluster/ui/Tty.cpp:144`	Memory	An agent's audio display with that file. at + 20 <= bytes.size().	`tests/display_bounds.py`	4
The graph reads _nodes with an index from an older frame	`src/cluster/ui/TtyGraph.cpp:510`	Memory	A session closed between the press and the release on its node (a one-shot sub-session, the global session closing one). Keep the id at the press, find_ it at the release.	`tests/graph_tty.py`	4
A time past the range of the zone breaks the list of schedules for good	`src/cluster/Cron.cpp:52`	Crash & DoS	A paired device, a sub-session with sub_schedules, the global session Refuse times past year 9999 in when_; zone_clock never throwing	`tests/schedule_rules.py`	4
A field of another type in a file of another tool stops the supervisor at its start	`src/cluster/Supervisor.cpp:603`	Crash & DoS	Any file under ~/.claude written by another tool or an agent A try per file (or read the fields by type) in supervisor_agents and title_	`tests/supervisor_safe.py`	4

Finding	Where	Category	What, the fix	Test	Pass
command_label: `migrat` can never match, a young migration is killed and re-run by an update	`src/cluster/Tools.cpp:1559`	Logic	An update with a migration started less than a minute before migrat\w* in the pattern	`tests/job_labels.py`	4
cluster-run hangs for ever on a command reading the terminal, Ctrl+C does nothing, its slot stays taken	`src/run/cluster-run.cpp:168`	Crash & DoS	A command asking something on the terminal (a password prompt) from the user's own shell tcsetpgrp when stdin is a terminal, SIGCONT with the signals forwarded	`tests/cluster_run_tty.py`	4
Finished tasks are never removed: state.json and each sync grow for ever	`src/cluster/Manager-Schedules.cpp:120`	Crash & DoS	A repeating schedule with action task or spawn Archived tasks dropped after some days or past a count; no answer in the sync	`tests/task_archive.py`	4
A stopped job is killed by its timeout	`src/cluster/Orchestrator.cpp:280`	Logic	job_stop, or a stop by the pressure of the computer, longer than what is left of its timeout Subtract now - stoppedAt, or skip the stopped state	`tests/job_end_told.py`	4
A cycle in the after of session_fanout: a group that never ends	`src/cluster/Manager-Groups.cpp:120`	Logic	The global session writing such a group Refuse a cycle at creation	`tests/task_events.py`	4
on_event command every constantly is checked each 5 s, not 2 s	`src/cluster/Manager-Schedules.cpp:618`	Logic	A task with every: constantly and no schedule due >= 2 at :725	`tests/task_events.py`	4
on_event git_push on a branch not pushed yet misses its first push	`src/cluster/Manager-Schedules.cpp:648`	Logic	task_add on_event {type: git_push, branch: } before the branch exists A flag for the first look, apart from the value	`tests/task_events.py`	4
_handoff changed without the lock while save() copies it	`src/cluster/Manager-Schedules.cpp:722`	Concurrency	A restart with prompts kept in a queue, saves from other threads meanwhile Take the entry out under *mutex, send outside it; handoff* on one thread only	`tests/handoff_limit.py`	4
The scan of the transcripts stops at a dangling link or at one bad line: the usage numbers wrong or frozen	`src/cluster/Usage.cpp:425`	Logic	A dangling .jsonl link, or one line of another shape, under ~/.claude/projects (a file of another tool). A separate error_code for the per-entry calls; try/catch around each file; no erasing of unseen files when the walk ended early.	`tests/usage_scan.py`	4
A null sessionId in `claude agents --json` stops the core from starting	`src/cluster/Manager.cpp:1009`	Crash & DoS	Output of another tool: any listed agent with a non-string sessionId or id, while the global session has a conversation to resume. Check is_string() on both fields, or move the block inside the try that follows it.	`tests/state_bad_item.py`	4
One opencode session with a null title fails the list of every agent	`src/cluster/External.cpp:257`	Crash & DoS	Output of another tool: opencode installed with a field of another kind. try/catch per item in opencode_, or around its call on line 291.	`tests/external_opencode.py`	4
A credentials file of another shape ends the account thread holding its lock and its busy flag, until a restart	`src/cluster/Usage.cpp:271`	Crash & DoS	~/.claude/.credentials.json with accessToken or expiresAt of another kind (a change of Claude Code). try/catch in the thread that clears _accountBusy on every exit; a small RAII for the flock and its descriptor.	`tests/account_shape.py`	4
The text of a conversation is on the command line of the description and of the chat	`src/cluster/Manager-Describe.cpp:80`	Secrets	Every automatic description (turns 1, 3, 9...), every Chat about this, every text spoken: for up to 90 s each, on a computer shared with other users. Give the prompt on stdin (claude -p and voice-say both read it): capture with an input fd, a memfd as in detach_fed_.	`tests/oneshot_input.py`	4
A callback was dropped when the session told was away for a moment	`src/cluster/Manager.cpp:2247`	Logic	The global session starting again, or the agent of a parent restarting at that moment: a notice, the callback gone. Tried for two minutes, then the notice.	`tests/callbacks.sh`	5
The pairing code was read out of its lock when the web access opened	`src/cluster/Web.cpp:821`	Concurrency	A code renewed at that moment: its string read while it is replaced. Copied under the lock.	`tests/web_gate.py`	5

Finding	Where	Category	What, the fix	Test	Pass
The size of a terminal of the page was read out of its lock	`src/cluster/WebTty.cpp:224`	Concurrency	Two pages of a device opening at once. Read under the lock of the terminal.	`tests/web_tty_race.py`	5
A value of another shape for `machine_later` in `state.json` failed the request	`src/cluster/Manager.cpp:1865`	Crash & DoS	`std::stoll` on a text that is no number. Caught, the question asked as if never answered.	`tests/state_bad_item.py`	5
Each core ending left a `gdbus monitor` process behind	`src/cluster/Manager.cpp:193`	Crash & DoS	`popen` gave the monitor a pipe, and a closed pipe stops it only at its next line, which may never come: one process left per core, and its thread detached used the manager after its end. Its own process, killed with the manager, and with the core in any case by `PR_SET_PDEATHSIG` ; its thread joined.	`tests/notify_monitor.py`	5

4. Open

What	Why it stays	The decision needed
The local authority is valid 20 years, no name constraint (F5 of the first audit)	Changing it asks every device to trust a new one. Its key is `0600` in a private folder	Reissue it with a name constraint and a shorter life, or keep it: yours
Any device can change the code by wrong codes (rest of F9)	A nuisance of the pairing only (5 wrong codes block an address), nothing else reached	None, unless it bothers you
`[web] settings = all` amounts to code execution (F7), **`web.shell = false` stops `!command`, not an agent asked to run it** (F8)	Documented in the security pages: what an agent may do is its permission mode	None
A big paste in the terminal takes about about 1.4 s per MB (6 MB in 8.5 s)	FTXUI gives input character by character, 100 bytes per read. The popup shows its size meanwhile	Patch FTXUI, or nothing
FTXUI resets its sender at the quit while another thread posts an event (`ScreenInteractive::ExitNow` , seen by ThreadSanitizer)	Inside the library, in the last moments of a terminal. A crash there finds the terminal restored by the handler and the draft saved	Report it upstream, or nothing
System packages: `libgcc` , `libstdc++` , `libstdc++-devel` `16.2.1-2.fc44` , advisory `FEDORA-2026-d732fb97a0` , moderate	Installed on this computer, not in this repository. Its code reachable: not determined	`SUDO_ASKPASS=~/.local/bin/sudo-askpass sudo -A dnf upgrade libgcc libstdc++ libstdc++-devel`

5. Tools and false positives

5.1 Tools

Tool	Ran	Result
AddressSanitizer + UndefinedBehaviorSanitizer (clang, Debug)	every pass	no memory error left; time-bound failures only on the slow build
ThreadSanitizer (clang)	passes 5 to 7	races fixed; 3 benign reports of the standard library left
libFuzzer on the parsers (JSON depth, Cron, Display, Editor, web frames…)	passes 2 and 7	crashes found in pass 2, fixed; 472295 runs clean in pass 7
Running the program isolated (own config, data, socket, port)	every pass	oversized and malformed frames, no auth, forged tokens, path traversal, concurrent requests, disconnects
`xstyle --rtk` (casts, silent excepts, unchecked returns)	every pass	findings confirmed by reading; 6 minor style notes left
Dependency check (OSV, dnf advisories)	pass 1 and 7	no vulnerable direct dependency reachable; one system advisory listed as open

Missing: `clang-tidy`, `cppcheck`, `scan-build`, `semgrep`, `bandit`, `shellcheck`, `gitleaks`, `trufflehog`. To install the first three: `SUDO_ASKPASS=~/.local/bin/sudo-askpass sudo -A dnf install clang-tools-extra cppcheck clang-analyzer`. Not installed without asking.

5.2 False positives

Lead	Why it was dropped
ThreadSanitizer: `std::ctype<char>::narrow` while two regexes compile	A cache of single bytes inside libstdc++, every thread writing the same value: nothing of this code.
ThreadSanitizer: `free` in `tzset_internal` under `mktime`	glibc holds its own lock there, one ThreadSanitizer does not see.
`keep_warm.py`: a wake-up told as a turn	The fake agent answered the `initialize` of each start as a prompt, which a real agent does not do. The fake was fixed.
Tests failing under a sanitizer only (`settings_keys.py`, `plugins_settings_back.py`, `paste_import.py`, `keep_warm.py`, `web_tty_race.py`)	Timing: all of them pass on the optimized build. `gui_shapes.py` needs the Qt build, which is the optimized one.
`std::regex` stack overflow on long text	libstdc++ 16 has a non-recursive executor: tested on 10 million characters.
An exception of `onAction` in a notification	`notifyAction_` catches it.
Path traversal in `purge`	The ids come from the trash, never from the request.
XSS in `web.html`	Text escaped first, http(s) links only, a CSP nonce.
A job writing without end holds the orchestrator lock	Tested with `yes`: every command answered within milliseconds.
`machine.md` world-readable	Mode 0644 in a folder of mode 0700.
`core_supervisor.py` fails under ASan	A test artifact: ASan catches the SIGSEGV the test sends.
`reveal_restore.py` failed once	Flaky under load: it read half a frame. Three runs of three pass.
Sparkline index out of bounds (`inf / inf`)	Undefined behaviour in the code, no crash observed: kept low, fixed with the chart finding.